

NIST Basis / BLACKOWL

Dokumentasi infrastruktur, aplikasi, API, database dan keamanan | 9 Oktober 2026

Dokumentasi teknis NIST Basis / BLACKOWL

Tanggal pemeriksaan: **9 Oktober 2026**, zona waktu Asia/Bangkok. Basis: source workspace saat ini, termasuk perubahan lokal. Dokumentasi berbahasa Indonesia; nama field, enum, dan endpoint dipertahankan sesuai kode.

Isi paket

- Infrastruktur: runtime, Docker, jaringan, volume, environment, integrasi, dan operasional.
- Aplikasi: modul, struktur kode, alur bisnis, lifecycle, hak akses, dan frontend.
- API: seluruh **191 endpoint HTTP API** dari 24 kelompok, autentikasi, input, response, dan contoh.
- Database dan relasi: tabel, kolom, foreign key, constraint, JSONB, serta migrasi.
- Keamanan dan praktik rekayasa: temuan, perbaikan, kontrol yang ada, dan batas verifikasi.
- Operasi dan pengujian: instalasi, rilis, backup, restore, troubleshooting, dan quality gate.
- Lampiran implementasi API: deklarasi route dan kontrak handler dari source untuk setiap endpoint.
- Katalog API JSON: inventaris yang dapat diproses alat lain; bukan spesifikasi OpenAPI hasil validasi schema.
- Paket dokumentasi ZIP: seluruh dokumen dan diagram.
- Dokumen PDF: siap dibaca dan dicetak.
- Dokumen HTML lengkap: dapat dibuka offline dan dicetak.

Folder `images/` menyediakan enam diagram dalam **SVG** untuk kualitas vektor dan **PNG resolusi 2x** untuk presentasi. Diagram menampilkan arsitektur aktual, bukan data perangkat atau topologi produksi pengguna.

Cakupan dan cara memperbarui

Inventaris API dibaca dari router Express yang terdaftar, termasuk route aset yang dibentuk dengan loop. Kamus database berasal dari DDL dan migrasi source; bukan dump database produksi. Kredensial, isi `.env`, record bisnis, dan upload pengguna tidak disertakan.

Jalankan dari root proyek:

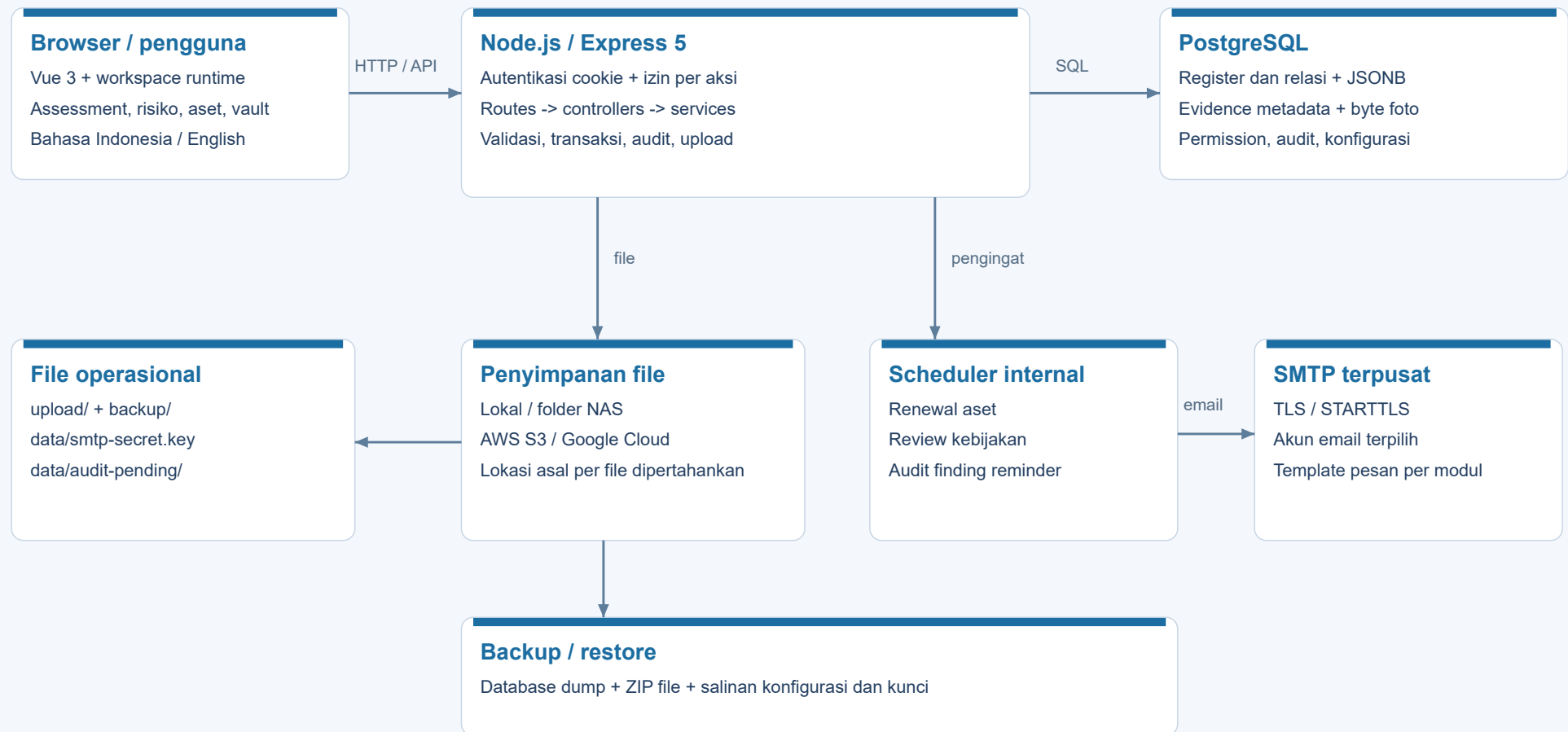
```
node scripts/document-api-catalog.js  
python scripts/build-technical-documentation.py
```

Generator gambar membutuhkan Pillow dan font Arial pada Windows. PDF dibuat dari HTML melalui browser. Perubahan setelah tanggal pemeriksaan perlu regenerasi dan review. Rancangan produksi/peningkatan diberi label **rekomendasi**, sehingga tidak dianggap sudah terpasang.

Detail infrastruktur

Arsitektur aplikasi dan integrasi

Implementasi saat ini: modular monolith; frontend dan API pada origin yang sama.



NIST Basis / BLACKOWL | Source workspace | 09-10-2026 | Tidak memuat data atau kredensial produksi

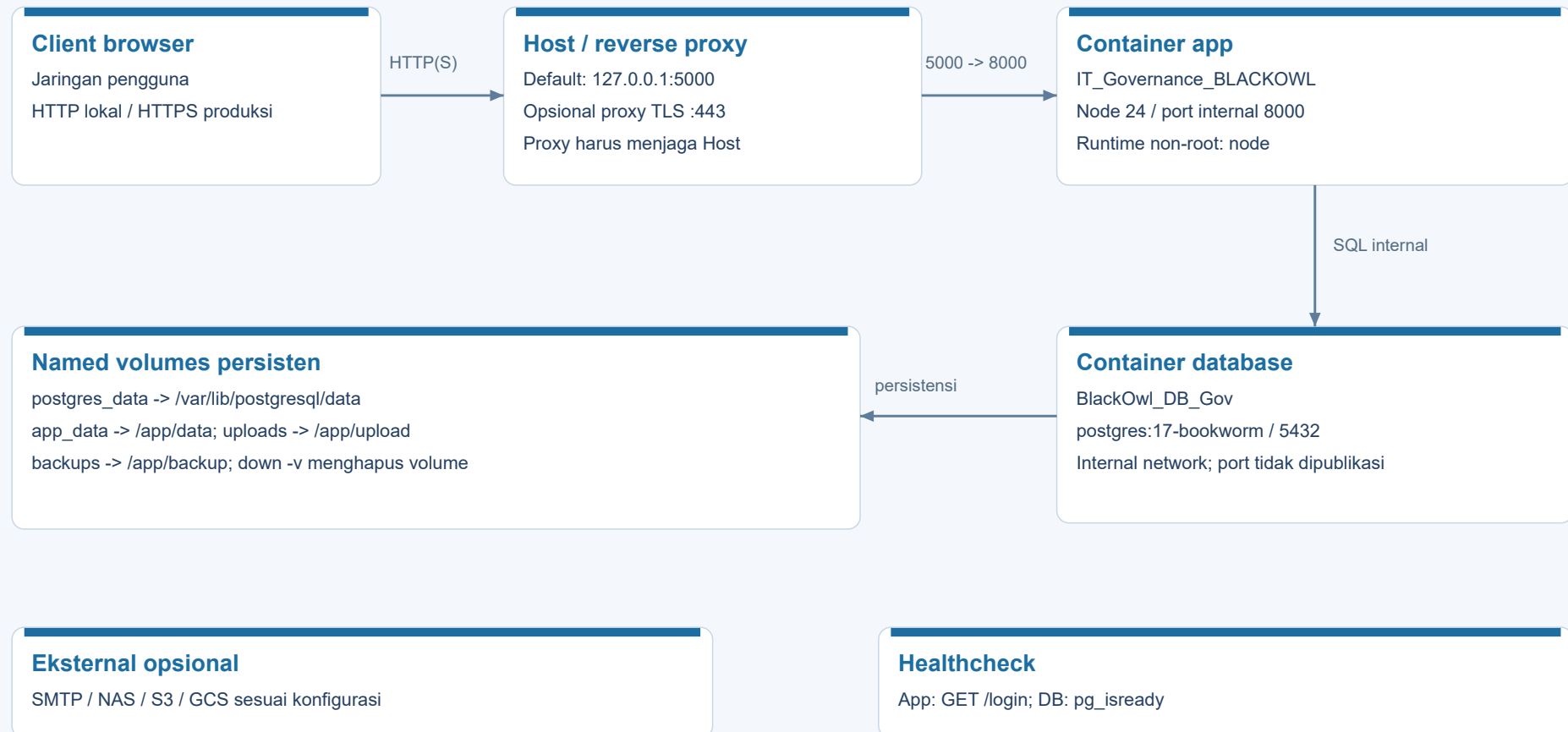
Topologi aktual

Aplikasi adalah modular monolith. Satu proses Express menyajikan halaman publik, workspace Vue hasil build, REST API, dan scheduler. PostgreSQL menyimpan data operasional. Penyimpanan file dapat lokal, folder shared/NAS, S3, atau GCS; SMTP bersifat opsional. Tidak terdapat Redis, message broker, service mesh, Kubernetes, atau load balancer bawaan dalam konfigurasi repository.

Komponen	Implementasi	Lokasi konfigurasi
Backend	Node.js; Express 5; pool <code>pg</code>	<code>src/server.js</code> , <code>src/app.js</code>
Frontend	Vue 3, Vite, Tailwind, Tiptap, DOMPurify	<code>frontend/client/</code> , <code>package.json</code>
Database	PostgreSQL; Docker major 17	<code>compose.yaml</code> , <code>src/config/database.js</code>
Build Docker	Node 24 trixie slim, multi-stage	<code>Dockerfile</code>
Runtime Docker	Non-root <code>node</code> , client PostgreSQL 17	<code>Dockerfile</code>
SMTP	Nodemailer, TLS/STARTTLS, akun terpusat	<code>src/services/smtpService.js</code>
Backup database	<code>pg_dump</code> , <code>pg_restore</code> ; custom dump	<code>src/services/backupService.js</code>
Backup file	ZIP + manifest; baca storage sesuai asal file	<code>src/services/fileBackupService.js</code>

Deployment Docker dan jaringan

Konfigurasi Compose aktual; reverse proxy HTTPS adalah rancangan produksi opsional.



Deployment

Project Compose bernama `it_governance_blackowl` . Container app `IT_Governance_BLACKOWL` , container DB `BlackOwl_DB_Gov` . Aplikasi menunggu healthcheck database sebelum dijalankan; restart policy `unless-stopped` , app `init: true` , grace period 30 detik.

Koneksi	Default	Keterangan
Browser -> host	<code>127.0.0.1:5000</code>	<code>BLACKOWL_BIND_IP</code> , <code>BLACKOWL_PORT</code> dapat diubah
Host -> app	Host 5000 -> container 8000	Server Express <code>PORT=8000</code>
App -> DB	<code>db:5432</code>	Port DB tidak dipublikasikan ke host
Dev frontend	5173 -> backend 8000	Proxy Vite untuk API dan aset terkait
SMTP	587 default	Port akun dapat dikonfigurasi; STARTTLS default
Named volume	Mount	Isi yang harus persisten
<code>postgres_data</code>	<code>/var/lib/postgresql/data</code>	Cluster PostgreSQL
<code>app_data</code>	<code>/app/data</code>	Seed, kunci SMTP, antrean audit
<code>uploads</code>	<code>/app/upload</code>	File lokal dan staging <code>.incoming</code>
<code>backups</code>	<code>/app/backup</code>	Dump database; ZIP pada <code>backup/files</code>

`docker compose down` mempertahankan named volume. `down -v` menghapusnya. Folder NAS dan credential cloud harus dipasang/disediakan pada runtime jika digunakan; Compose saat ini belum memasangnya otomatis.

Environment dan konfigurasi

Nilai berikut berasal dari konfigurasi kode atau contoh Docker; nilai rahasia deployment tidak dibaca atau dicantumkan.

Variable	Default / fungsi
<code>NODE_ENV</code>	<code>development</code> ; Docker <code>production</code>
<code>PORT</code>	8000
<code>DATABASE_URL</code>	Alternatif connection string pada pool utama
<code>DB_HOST</code> , <code>DB_PORT</code>	localhost, 5432; Compose host <code>db</code>

Variable	Default / fungsi
DB_NAME , DB_USER	Native nist_basis , postgres ; Compose BlackOwl_DB_Gov , blackowl
DB_PASSWORD	Tidak ada password bawaan pada env config; wajib isi sesuai DB
DB_SSL	true untuk TLS; default false
DB_SSL_REJECT_UNAUTHORIZED	Verifikasi sertifikat aktif kecuali diset false
DB_SSL_CA	CA tambahan bila diperlukan
SESSION_COOKIE_SECURE	Production true kecuali eksplisit false; dev false kecuali true
LOG_HTTP_REQUESTS	true mengaktifkan log request; gunakan saat troubleshooting
PG_DUMP_PATH , PG_RESTORE_PATH	Override executable client PostgreSQL
BLACKOWL_DB_PASSWORD	Wajib untuk Compose
BLACKOWL_PORT , BLACKOWL_BIND_IP	5000, 127.0.0.1
BLACKOWL_COOKIE_SECURE	false untuk HTTP lokal; true untuk HTTPS
TZ	Compose Asia/Bangkok; reminder aset juga eksplisit menggunakan zona ini
AWS credential chain	Diberikan ke runtime server, tidak melalui UI
GCS Application Default Credentials	Diberikan ke runtime server, tidak melalui UI

Pool database: maksimum 10 koneksi, idle timeout 30 detik, connection timeout 5 detik. Provisioning script masih membaca DB_* ; ketika memilih DATABASE_URL , pastikan DB_* provisioning menunjuk database yang sama. Jangan mengasumsikan kedua mekanisme otomatis identik.

Penyimpanan dan integrasi

Setelan aktif di file_storage_settings ; setiap file menyimpan lokasi asal melalui file_storage_locations . Pergantian mode hanya menentukan lokasi upload baru, tidak memigrasikan file lama. Pergantian/download file lama tetap memakai lokasi asal. Kegagalan cloud tidak dialihkan diam-diam ke lokal.

SMTP menyimpan ciphertext AES-256-GCM di database; kunci berada di data/smtp-secret.key . Salinan database saja tidak cukup untuk mendekripsi password setelah pindah host. Pertahankan kunci yang sesuai dan ACL hanya untuk akun server.

Kapasitas dan observabilitas

Healthcheck container app: `GET /login` , interval 30 detik, timeout 5 detik, start period 120 detik. Ini mengecek respons HTTP, bukan seluruh kesiapan DB. Database: `pg_isready` interval 5 detik. `/api/health` dan `/api/health/db` membutuhkan login.

Log tersedia pada stdout/stderr; audit di `audit_events` , fallback pada `data/audit-pending` . Scheduler aset memeriksa startup dan tiap jam; recovery audit mencoba ulang tiap 30 detik. Antrean audit maksimum 1000 file, 128 KiB per event; 100 event per putaran recovery.

Rekomendasi produksi: HTTPS melalui reverse proxy, database dan storage di jaringan terbatas, satu instance app sampai sesi/limiter menjadi shared, backup off-host, monitoring error dan kapasitas disk, serta proses restore rehearsal. Ukuran CPU/RAM/disk harus ditentukan lewat uji beban jumlah aset, catatan, upload, dan concurrency; repository tidak menetapkan sizing teruji atau target RTO/RPO.

Sumber: `compose.yaml` , `Dockerfile` , `docker.env.example` , `src/config/` , `src/services/storageService.js` , `cloudStorageService.js` , `smtpService.js` , `auditRecoveryService.js` .

Detail aplikasi dan struktur kode

Lapisan dan tanggung jawab

Lapisan	Path	Tanggung jawab
Bootstrap	src/server.js	Provision DB, DDL/seed, folder, listen, scheduler
HTTP	src/app.js	Header, audit, parser, origin, session, routing, static, errors
Routes	src/routes/	Method/path, izin, parameter, multipart
Controllers	src/controllers/	Konversi request/response; sebagian modul memakai handler inline
Domain services	src/services/	Validasi bisnis, SQL, transaksi, storage, SMTP, backup
Shared contracts	src/shared/	Skor CIA, stencil diagram, aturan bersama
SQL	database/	Schema dasar, akun, ownership, migrasi relasi
Vue UI	frontend/client/src/workspace/components/	Tampilan fitur dan modal
Runtime fitur	frontend/client/src/workspace/features/	Logika DOM untuk fitur kompatibilitas
Runtime loader	frontend/client/src/workspace/runtime.js	Import raw JS berurutan dan shared scope
Generated assets	frontend/public/vue/	Hasil build; jangan diedit langsung
Quality tools	test/ , scripts/	Unit, integrasi, browser, provisioning dan generator

Frontend memakai dua pola: komponen Vue reaktif (antara lain Asset Management, Knowledge Notes, Threat Modelling) dan komponen DOM statis yang dikelola runtime lama. Urutan loader dan ID DOM merupakan kontrak kompatibilitas. Shared scope belum memberikan isolasi state per modul seperti modul Vue murni; refaktor bertahap memerlukan pengujian regresi.

Inventaris fitur

Modul	Kapabilitas dan hubungan
NIST CSF 2.0	Kontrol, policy/practice score, catatan, attachment, ringkasan fungsi

Modul	Kapabilitas dan hubungan
NIST Privacy	Kontrol privasi dan assessment state tersendiri
Framework / ISO 27001	Framework, kontrol, target kategori, security objectives
SOA	Applicability dan evidence kontrol ISO
Risk Management	Risk register, CIA 5x5, inherent/residual risk, treatment, dropdown, indikator
Risk Acceptance	Form keputusan, mitigasi, tanggal, bidang tanda tangan, export PDF
Asset Register	Identitas, lifecycle, owner, CIA, vendor pengelola opsional, related risk, renewal, foto
Rak Server	Rak 1-60 U, front/rear, full/single depth, install/move, drag/drop, daftar perangkat
Modelling Asset Register	Kanvas relasi berarah, palette register, multi-edge, zoom, versi layout
Knowledge Vault	Folder/subfolder, Markdown/editor, wiki-link/search, gambar, import/export ZIP/JSON
Policy Register	Kebijakan, item isi, lampiran, related notes, review, kalender, reminder
TPRM	Vendor assessment, risk register vendor, tiering, linked risks, status hubungan
Due Diligence / Templates	Respons kuesioner dan template sections/questions
Audit Finding Tracker	Hierarki audit -> finding -> followup/evidence, lampiran dan reminder
Personel / Sertifikasi	Pegawai terdaftar, supervisor, sertifikasi, roadmap dan layout
Uploaded Files	Daftar pusat semua modul, owner, pencarian, download, replacement, delete referensi
Administrasi	Akun, izin per aksi, SMTP, storage, audit, DB/file backup

Startup dan data sharing

Startup memprovision DB, menyiapkan schema/seed, memigrasikan store modul, membuat folder dan memulai scheduler. Startup melakukan penulisan database, sehingga tidak dipakai sebagai healthcheck dokumentasi. Assessment CSF ber-ID `default` ; Privacy `privacy` . Keduanya merupakan dokumen bersama, bukan partition per pengguna. Aplikasi belum menyediakan tenancy/organisasi terisolasi secara menyeluruh.

Autentikasi dan hak akses

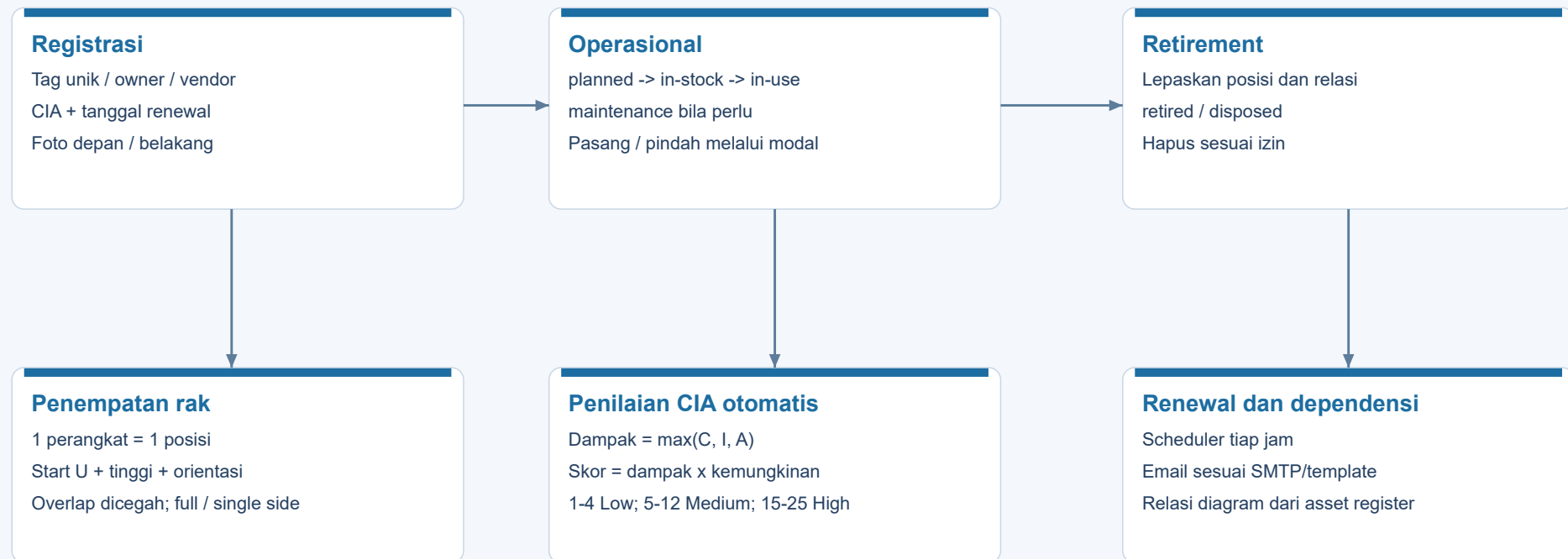
Login memvalidasi bcrypt, membuat token acak 32 byte, dan menyimpan session di Map. Cookie `nist_session` : HttpOnly, SameSite=Lax, Secure sesuai konfigurasi; usia 8 jam. Login baru mengganti sesi sebelumnya untuk username sama. Restart, perubahan password/role, penghapusan akun, dan restore DB mencabut sesi terkait sesuai service aplikasi.

Role: admin, approver, editor, viewer, user. Izin efektif memerlukan page allowed + Read + aksi Read/Create/Update/Delete. Admin bypass izin per halaman. Akun administratif, SMTP, storage, dan backup dibatasi admin.

Evidence menambahkan ownership. Jangan menentukan hak akses hanya dari label role atau tombol yang terlihat.

Siklus hidup aset, penempatan, dan risiko

Proses mengikuti prinsip ITSM; referensi change/tiket opsional, tanpa approval engine eksternal.



Semua perubahan register melalui modal; backend tetap memvalidasi ulang data dan hak akses.

Lifecycle aset

Tag aset unik; status `planned` , `in-stock` , `in-use` , `maintenance` , `retired` , `disposed` . Referensi change/tiket opsional. Lepaskan posisi dan relasi sebelum retirement. Aset operasional harus dipensiunkan sebelum dihapus; status `planned` dapat dihapus untuk koreksi pencatatan.

Satu perangkat punya satu posisi fisik. `startUnit` dihitung dari bawah; rentang berakhir `startUnit + height - 1` . Kedalaman penuh memakai kedua sisi; perangkat satu sisi pada orientasi berbeda boleh memakai U sama. Backend menolak overlap, over-capacity, nonfisik (Software/License/Cloud), aset `retired/disposed`, serta pemasangan ulang tanpa konteks pemindahan. Drag/drop mengisi modal; DB baru berubah setelah Simpan.

Foto PNG/JPEG/WebP max 5 MiB per sisi. Byte asli tersimpan tanpa kompresi ulang; `object-fit: scale-down` menghindari pembesaran melampaui resolusi sumber. Foto panel ditampilkan sesuai orientasi dan tinggi U; foto rak keseluruhan adalah referensi terpisah. File tercatat di Uploaded Files; foto history tetap tersedia ketika foto aktif diganti lewat modul.

Relasi: `connects-to` , `depends-on` , `protects` , `balances` , `hosts` , `backs-up` . Tidak boleh self-link atau duplikat source/target/type. Multi-edge dan arah sebaliknya diperbolehkan; kurva diagram dibedakan. `depends-on` berarti sumber bergantung pada tujuan; `hosts` berarti sumber berjalan pada host tujuan. Analisis hanya menelusuri dependensi yang dicatat, bukan discovery jaringan atau simulasi gangguan.

Layout disimpan dengan version untuk mencegah overwrite edit bersamaan. Foto, aset, dan import disimpan atomik pada jalur terkait. Export JSON format `nist-basis-asset-management` versi 1: aset, rak, posisi, relasi, node, foto base64, dan template email. Import merge berdasarkan tag/nama; ID dipetakan ulang; konflik membatalkan transaksi. Vendor/risk eksternal harus sudah tersedia. Kredensial SMTP tidak dipindahkan oleh export ini.

Daftar aset newest-to-oldest menurut `created_at`; data lama menggunakan `updated_at` sebagai fallback migrasi. Daftar rak diurutkan nama; posisi berdasarkan U; relasi berdasarkan tipe. Filter hanya mengubah tampilan, bukan okupansi atau relasi tersimpan.

Penilaian CIA 5x5

C, I, A dan likelihood berada pada skala 1-5. $\text{Impact} = \max(C, I, A)$; $\text{score} = \text{impact} \times \text{likelihood}$. Score 1-4 Low, 5-12 Medium, 15-25 High. Tidak ada score 13/14 dari perkalian integer 1-5. Backend menghitung ulang; nilai `impact/rating` kiriman client tidak dipercaya untuk CIA lengkap. Risk Management menghitung residual rating dari residual likelihood x residual impact dengan batas yang sama. Data legacy tanpa CIA lengkap dapat memerlukan pengisian ulang; bukan dianggap sudah dinilai.

Related risk adalah tautan ke Risk Register, berbeda dari hasil CIA aset. Vendor pengelola mengacu TPRM dan opsional; vendor perangkat/manufacturer merupakan field informasi terpisah.

Knowledge, policy, evidence, dan backup

Knowledge mempunyai title/folder unik tanpa mengubah isi Markdown. Update membutuhkan version. Import baru menyimpan file MD/TXT/JSON asli dan gambar ke evidence library bersama hasil parsing. Import historis yang tidak menyimpan original bytes tidak dapat direkonstruksi persis.

Policy dapat memilih note individual atau semua note di folder/subfolder. Subfolder tertutup default; pencarian membuka folder hasil. Pemilihan folder mencakup seluruh descendants, termasuk hasil yang tersembunyi oleh filter. Isi note terkait ikut pencarian policy. Link policy-note disimpan sebagai array JSONB, bukan FK individual.

Semua modul menggunakan library evidence terpusat. Admin dapat mengelola seluruh file; pengguna mengikuti ownership dan izin aksi. Hapus file di library dapat melepaskan referensi lintas modul; melepas satu attachment dilakukan melalui modul asal. File Backup tidak memulihkan record bisnis; Database Backup dan File Backup diperlukan bersama.

Bahasa, UI, dan proses development

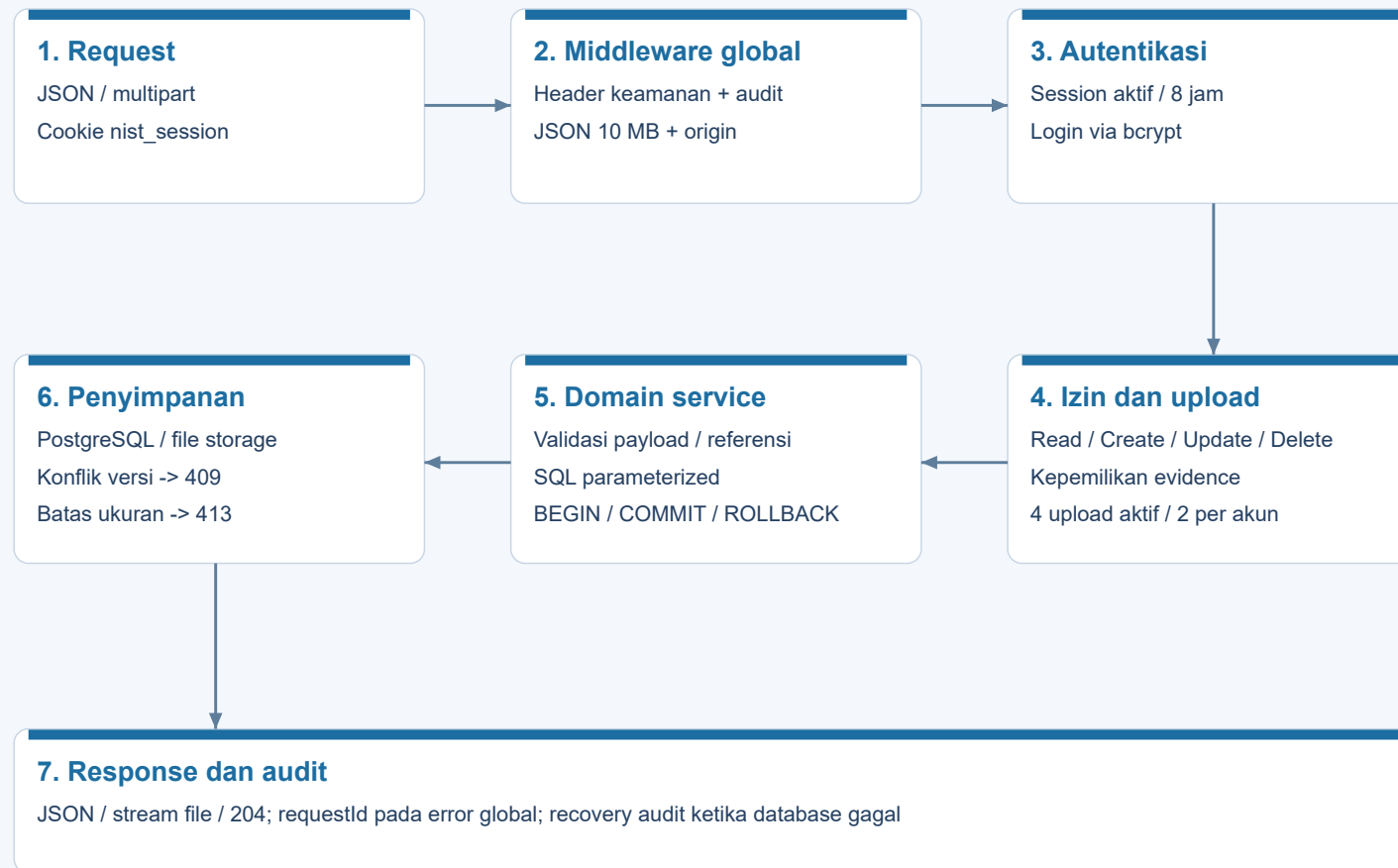
`frontend/public/i18n.js` menyimpan kamus ID/EN, dynamic patterns, pilihan `nist-basis-language`, dan event pergantian bahasa. Enum/value form harus eksplisit agar label terjemahan tidak mengubah data API. Konten pengguna menggunakan batas no-translate bila sesuai. Tambah/ubah fitur aset memakai modal, konfirmasi mutasi, busy lock dan pesan error.

Edit source, jalankan build, verifikasi unit dan browser, lalu restart backend bila ada perubahan server/migrasi. Lihat runbook untuk perintah. Prinsip industri yang dipakai: separation of concerns, validasi server, parameterized SQL, transaksi satu koneksi, least privilege, optimistic concurrency, audit, dan backup terpisah. Status approval pada register bukan workflow bertingkat atau tanda tangan digital kriptografis.

Detail dan katalog API

Alur API, autentikasi, dan otorisasi

Pipeline aktual: API diaudit; sesi dan pembatas permintaan berada dalam proses aplikasi.



NIST Basis / BLACKOWL | Source workspace | 09-10-2026 | Tidak memuat data atau kredensial produksi

Kontrak umum

Base URL native `http://localhost:8000/api` , Compose `http://localhost:5000/api` . Gunakan origin deployment aktual dan HTTPS pada produksi. API belum memakai prefix versi `/v1` , bearer token/OAuth, atau kontrak OpenAPI tervalidasi bawaan.

Seluruh endpoint selain login/logout auth melewati sesi. Browser same-origin otomatis menyertakan cookie. Integrasi CLI menyimpan cookie jar dari login; jangan menaruh password atau cookie produksi di dokumentasi/log. Request JSON memakai `Content-Type: application/json` ; upload memakai multipart dan boundary otomatis. Parser JSON dibatasi 10 MiB. Origin mutasi diperiksa ketika header Origin tersedia; cookie SameSite=Lax adalah kontrol tambahan, bukan token CSRF khusus.

Format response bervariasi per endpoint: array list, object record, `{ok:true}` , stream file/ZIP/PDF, atau 204 tanpa body. API menggunakan camelCase pada banyak register, tetapi rack placements/reasons dan beberapa indikator masih mengembalikan snake_case. ID BIGSERIAL dapat berupa string dari `pg` ; jangan mengasumsikan seluruh ID aman dikonversi ke Number. Asset/rack/relasi memakai UUID; Risk Register memakai string seperti `CSR - 001` .

Status	Pemakaian
200	Baca, update, action sukses
201	Pembuatan resource pada handler yang menetapkannya
204	Hapus/logout/reset tertentu; jangan parse JSON
400	Payload, path, enum, referensi/form/upload tidak valid
401	Kredensial salah atau session tidak aktif
403	Izin, ownership, origin atau admin-only ditolak
404	Record/file/route tidak ditemukan
409	Constraint, record digunakan, collision atau konflik versi
413	Batas upload/body terlampaui
429	Rate limit atau kapasitas upload; dapat memuat Retry-After
500	Error global yang tidak diekspos rinci kepada client
502/503	Beberapa handler khusus dapat melaporkan kegagalan integrasi/restore; error global hanya meneruskan status 4xx

Error global berbentuk `{"error":"...", "requestId":"..."}` ; handler lokal dapat hanya mengembalikan `error` . Jangan mengandalkan adanya requestId pada seluruh respons. Jangan melakukan retry mutasi secara buta setelah timeout; pastikan hasil sudah/belum tersimpan, terutama upload/import/email.

Upload dan tipe konten

Jalur	Multipart / batas aktual
/file	file ; functionName, kind policy/practice, rejectDuplicate opsional; 100 MiB/file
/files/batch	files ; efektif maksimum 20 file dari Multer walaupun route array cap 50; total 200 MiB selama streaming
/files/*path PUT	file , 100 MiB; ownership diperiksa sebelum parsing dan penulisan
Aset/foto rak	front , rear ; 5 MiB/sisi, max 2 file; data JSON pada registrasi multipart, removeFront/removeRear boolean string
/asset-management/import	file JSON; maksimum 100 MiB
/knowledge-notes/images	images satu gambar; paths JSON array; 10 MiB/file
/knowledge-notes/import-with-images	images max100, documents max200; payload, paths, documentPaths; 10 MiB/file dan total stream 100 MiB
Audit finding	file max10, 10 MiB/file; data dan parent sesuai kind
DB/file restore	backup ; 500 MiB/file; dump/JSON untuk DB, ZIP untuk file

Semua multipart API dibatasi 4 request aktif per proses dan 2 per akun. Evidence umum menerima PDF/DOC/DOCX/PPT/PPTX/PNG/JPG/GIF/WebP sesuai MIME+extension. Foto aset memeriksa bytes gambar; validasi seluruh dokumen belum merupakan antivirus/malware scanning.

Payload domain dan validasi

Field di bawah mencakup kontrak bisnis utama. Detail endpoint dan observed fields terdapat pada katalog/lampiran source; field bertanda derived dihitung backend. PUT pada beberapa register membutuhkan formulir lengkap, bukan PATCH universal.

Resource	Field dan batas
Login	username 3-50 karakter [A-Za-z0-9._-] , password max72 byte UTF-8
Profil	fullName; admin dapat mengubah security fields sesuai service; password memakai currentPassword/newPassword/confirmPassword
Izin	permissions array key dikenal; actions map boolean read/create/update/delete; write memerlukan read
Assessment	scores, policyScores, practiceScores, notes, attachments; state bersama default/privacy; attachments harus mereferensikan file yang boleh digunakan

Resource	Field dan batas
Asset	tag/name/owner wajib max150; type/status/criticality enum; serial/vendor/model/location/service/changeReference max250; description max2000; ownerEmail max254; dates YYYY-MM-DD; reminderEnabled boolean, reminderDays integer0-365; managedVendorId string ID TPRM atau null; assetAssessment C/I/A/likelihood integer1-5
Rack	name wajib max150, location wajib max250, units integer1-60
Placement	assetId/rackId UUID, startUnit/height integer>=1, facing front/rear, fullDepth boolean; previousRackId harus cocok untuk pindah existing; changeReference opsional
Asset relation	sourceId/targetId UUID berbeda, type enum enam relasi, notes max1000, changeReference max250
Asset diagram	nodes max500, setiap id UUID unik, x/y finite0-20000, version integer>=0; response version dinaikkan
Related risk	riskRegisterIds array unik max500; setiap riskId string nonkosong max150 dan benar-benar terdaftar
Risk Register	riskCategory/effectedAsset/deviceName/identificationRisk/likelihood/impact wajib sesuai validator; C/I/A1-5; impact/value/rating derived bila CIA lengkap; riskId dibuat backend; riskOwner/treatment/deadline/residual fields/comment/ref opsional sesuai service
Risk dropdown	fieldName dari kategori/asset/device/owner/treatment, optionValue, sortOrder; nama/type yang sudah dipakai tidak dapat diubah/hapus
Risk indicator	indicatorType, label wajib; score, description, sortOrder
Risk acceptance	requestorName, assetName, department, riskDescription, benefitJustification, mitigationPlan; businessOwnerDecision temporary/one_year/denied; cisDecision approved/denied/conditional; dates dan signature fields
TPRM questionnaire	vendorName wajib; status Draft/In progress/Complete/Expired/Final; result Pending/Approved/Approved with Conditions/Rejected; reviewDate, reviewer, notes, responses JSON
TPRM register	thirdParty/serviceDependency wajib; questionnaireId harus terdaftar dan nama vendor cocok; riskLevel tiga tier; assessmentStatus Not started/In progress/Complete/Accepted; relationshipStatus Active/Offboarded/Expired/Terminated; riskRegisterIds, dueDiligenceAssessment, nextReview, notes
Questionnaire template	name dan sections; sections berupa pasangan [judul, [pertanyaan...]] ; judul dan minimal satu pertanyaan tiap section
Policy	title/category/owner/reviewCycle/approvalStatus wajib saat create; lastReview, attachmentName/Path/Type, notes, items subtitle/content; relatedNotelds max10000 positive IDs
Knowledge note	title wajib max200 tanpa karakter filename/wiki-link khusus; content max1.000.000 byte; folder max500 path valid; update version integer>=1
Knowledge folder	path, atau source/destination untuk move; delete mode empty/all; root tidak boleh dihapus, self-descendant move ditolak
Threat model	name max200; diagram nodes max500/edges max1000; node finite coordinates, width>=60,height>=40; IDs unik; edges referensi node berbeda; threats STRIDE dengan severity/status/mitigation; update version

Resource	Field dan batas
Audit finding	kind audit/finding/followup/evidence; parentId mengikuti hierarki; title max200 wajib, reference max100, owner max160, description max10000; status Open/In progress/Closed; severity Low/Medium/High/Critical; dueDate valid
Certification	personnelId pegawai terdaftar wajib, certificationName wajib; issuer/referenceUrl HTTP(S), certificationLevel, status, dates, notes, layout fields
SMTP	host/username/from max254 tanpa CRLF; port1-65535; security tls/starttls; password opsional max4096; clearPassword; akun UUID/default; test to/smtpAccountId
Storage	mode local/shared/s3/gcs; shared directory absolut khusus di luar project/root; cloud bucket/prefix, region S3 wajib, projectId GCS opsional; credentials dari runtime

Contoh integrasi

Gunakan akun pengujian berizin. Contoh berikut bersifat dokumentasi dan tidak dijalankan terhadap data produksi.

```
curl -c cookies.txt -H 'Content-Type: application/json' \
  -d '{"username":"test.user","password":"REPLACE_WITH_TEST_PASSWORD"}' \
  http://localhost:8000/api/auth/login
curl -b cookies.txt http://localhost:8000/api/auth/me
curl -b cookies.txt http://localhost:8000/api/asset-management/assets
curl -b cookies.txt 'http://localhost:8000/api/files?details=true'
```

Contoh create aset (JSON; bila foto disertakan kirim payload ini sebagai multipart field `data`):

```
{
  "tag": "SRV-DEMO-001",
  "name": "Server Demo",
  "type": "Server",
  "status": "planned",
  "owner": "IT Operations",
  "ownerEmail": "owner@example.com",
  "criticality": "medium",
  "reminderEnabled": false,
  "reminderDays": 30,
  "managedVendorId": null,
  "assetAssessment": {
    "confidentiality": 3,
    "integrity": 4,
    "availability": 4,
    "likelihood": 3
  }
}
```

Response assetAssessment dihitung ulang: impact4, score12, level medium. Jangan mengirim terjemahan enum seperti Direncanakan sebagai status API; gunakan `planned` .

Contoh posisi baru; ganti ID dengan record yang sudah dibuat:

```
{
  "assetId": "00000000-0000-4000-8000-000000000001",
  "rackId": "00000000-0000-4000-8000-000000000002",
  "startUnit": 20,
  "height": 2,
  "facing": "front",
  "fullDepth": true,
  "changeReference": ""
}
```

Saat pindah aset existing, tambahkan previousRackId dari posisi terbaru. Konflik memberi 409, lalu muat ulang posisi. Diagram dan catatan membutuhkan version terbaru sebelum update. File path wildcard bisa memiliki beberapa segmen; encode tiap segmen URL dan jangan menerima path absolut atau `...`.

Seluruh endpoint terdaftar

Kolom izin mencantumkan guard route yang terbaca. Guard dinamis, ownership, dan validasi service tetap berlaku. Observed fields hanyalah pembacaan request eksplisit, bukan daftar field wajib/schema lengkap; gunakan tabel domain dan lampiran implementasi.

authRoutes

Method	Endpoint	Izin	Input terbaca	Source
POST	/api/auth/login	public	Kontrak domain / handler	src/routes/authRoutes.js:14
POST	/api/auth/logout	public	Kontrak domain / handler	src/routes/authRoutes.js:15
GET	/api/auth/me	session; pemeriksaan tambahan di handler/service (lihat source)	Kontrak domain / handler	src/routes/authRoutes.js:16
PUT	/api/auth/me	session; pemeriksaan tambahan di handler/service (lihat source)	Kontrak domain / handler	src/routes/authRoutes.js:17
PUT	/api/auth/me/password	session; pemeriksaan tambahan di handler/service (lihat source)	Kontrak domain / handler	src/routes/authRoutes.js:18
GET	/api/auth/users	admin	Kontrak domain / handler	src/routes/authRoutes.js:19
POST	/api/auth/users	admin	Kontrak domain / handler	src/routes/authRoutes.js:20
PUT	/api/auth/users/:id	admin	path: id	src/routes/authRoutes.js:21
DELETE	/api/auth/users/:id	admin	path: id	src/routes/authRoutes.js:22
GET	/api/auth/permissions	admin	Kontrak domain / handler	src/routes/authRoutes.js:23
PUT	/api/auth/permissions/:role	admin	path: role	src/routes/authRoutes.js:24

assetManagementRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/asset-management/export	asset-register + server-racks + asset-modelling: read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:17
POST	/api/asset-management/import	asset-register + server-racks + asset-modelling: read/create/update; TPRM/risk read jika ada referensi	Kontrak domain / handler	src/routes/assetManagementRoutes.js:18
GET	/api/asset-management/reminder-settings	asset-register:read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:26
PUT	/api/asset-management/reminder-settings	asset-register:update	Kontrak domain / handler	src/routes/assetManagementRoutes.js:27
GET	/api/asset-management/vendor-catalog	asset-register:read + tprm-register:read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:28
GET	/api/asset-management/risk-catalog	asset-register:read + risk-management:read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:29
GET	/api/asset-management/diagram	asset-modelling:read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:30
PUT	/api/asset-management/diagram	asset-modelling:update	Kontrak domain / handler	src/routes/assetManagementRoutes.js:31
GET	/api/asset-management/assets	asset-register:read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:35
DELETE	/api/asset-management/assets/:id	asset-register:delete	path: id	src/routes/assetManagementRoutes.js:36
GET	/api/asset-management/racks	server-racks:read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:35
DELETE	/api/asset-management/racks/:id	server-racks:delete	path: id	src/routes/assetManagementRoutes.js:36
GET	/api/asset-management/placements	server-racks:read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:35
DELETE	/api/asset-management/placements/:id	server-racks:delete	path: id	src/routes/assetManagementRoutes.js:36

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/asset-management/relations	asset-modelling:read	Kontrak domain / handler	src/routes/assetManagementRoutes.js:35
DELETE	/api/asset-management/relations/:id	asset-modelling:delete	path: id	src/routes/assetManagementRoutes.js:36
PUT	/api/asset-management/assets/:id/related-risks	asset-register:update + risk-management:read	body: riskRegisterIds; path: id	src/routes/assetManagementRoutes.js:44
POST	/api/asset-management/assets	asset-register:create	Kontrak domain / handler	src/routes/assetManagementRoutes.js:45
PUT	/api/asset-management/assets/:id	asset-register:update	path: id	src/routes/assetManagementRoutes.js:46
POST	/api/asset-management/racks	server-racks:create	Kontrak domain / handler	src/routes/assetManagementRoutes.js:48
PUT	/api/asset-management/racks/:id	server-racks:update	path: id	src/routes/assetManagementRoutes.js:49
GET	/api/asset-management/catalog	session; pemeriksaan tambahan di handler/service (lihat source)	Kontrak domain / handler	src/routes/assetManagementRoutes.js:51
PUT	/api/asset-management/placements	server-racks:update	Kontrak domain / handler	src/routes/assetManagementRoutes.js:52
POST	/api/asset-management/relations	asset-modelling:create	Kontrak domain / handler	src/routes/assetManagementRoutes.js:53
PUT	/api/asset-management/relations/:id	asset-modelling:update	path: id	src/routes/assetManagementRoutes.js:54
GET	/api/asset-management/photos	session; pemeriksaan tambahan di handler/service (lihat source)	Kontrak domain / handler	src/routes/assetManagementRoutes.js:55
GET	/api/asset-management/photos/:kind/:id/:side	assets: asset-register; racks: server-racks; read foto aset juga via server-racks	path: kind, id, side	src/routes/assetManagementRoutes.js:57

Method	Endpoint	Izin	Input terbaca	Source
PUT	/api/asset-management/photos/:kind/:id	assets: asset-register; racks: server-racks; read foto aset juga via server-racks	path: kind, id	src/routes/assetManagementRoutes.js:58

knowledgeNoteRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/knowledge-notes	knowledge-notes:read	Kontrak domain / handler	src/routes/knowledgeNoteRoutes.js:29
GET	/api/knowledge-notes/folders	knowledge-notes:read	Kontrak domain / handler	src/routes/knowledgeNoteRoutes.js:30
GET	/api/knowledge-notes/images	knowledge-notes:read	Kontrak domain / handler	src/routes/knowledgeNoteRoutes.js:31
GET	/api/knowledge-notes/images/:id	knowledge-notes:read	path: id	src/routes/knowledgeNoteRoutes.js:32
POST	/api/knowledge-notes/images	knowledge-notes:create	Kontrak domain / handler	src/routes/knowledgeNoteRoutes.js:36
PUT	/api/knowledge-notes/images/:id	knowledge-notes:update	body: folder; path: id	src/routes/knowledgeNoteRoutes.js:40
DELETE	/api/knowledge-notes/images/:id	knowledge-notes:delete	path: id	src/routes/knowledgeNoteRoutes.js:41
POST	/api/knowledge-notes/import-with-images	knowledge-notes:create	body: payload, documentPaths	src/routes/knowledgeNoteRoutes.js:42
POST	/api/knowledge-notes/folders	knowledge-notes:create	body: path	src/routes/knowledgeNoteRoutes.js:52
PUT	/api/knowledge-notes/folders	knowledge-notes:update	body: source, destination	src/routes/knowledgeNoteRoutes.js:53
DELETE	/api/knowledge-notes/folders	knowledge-notes:delete	body: path, mode	src/routes/knowledgeNoteRoutes.js:54
GET	/api/knowledge-notes/export	knowledge-notes:read	Kontrak domain / handler	src/routes/knowledgeNoteRoutes.js:55

Method	Endpoint	Izin	Input terbaca	Source
POST	/api/knowledge-notes/import	knowledge-notes:create	body: notes, folders	src/routes/knowledgeNoteRoutes.js:68
POST	/api/knowledge-notes	knowledge-notes:create	Kontrak domain / handler	src/routes/knowledgeNoteRoutes.js:69
PUT	/api/knowledge-notes/:id	knowledge-notes:update	path: id	src/routes/knowledgeNoteRoutes.js:70
DELETE	/api/knowledge-notes/:id	knowledge-notes:delete	path: id	src/routes/knowledgeNoteRoutes.js:71

threatModelRoutes

Method	Endpoint	Izin	Input terbaca	Source
POST	/api/threat-modelling/validate	threat-modelling:read	Kontrak domain / handler	src/routes/threatModelRoutes.js:4
GET	/api/threat-modelling	threat-modelling:read	Kontrak domain / handler	src/routes/threatModelRoutes.js:5
POST	/api/threat-modelling	threat-modelling:create	Kontrak domain / handler	src/routes/threatModelRoutes.js:6
PUT	/api/threat-modelling/:id	threat-modelling:update	path: id	src/routes/threatModelRoutes.js:7
DELETE	/api/threat-modelling/:id	threat-modelling:delete	path: id	src/routes/threatModelRoutes.js:8

auditFindingRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/audit-finding-tracker/reminder-settings	admin	Kontrak domain / handler	src/routes/auditFindingRoutes.js:9
PUT	/api/audit-finding-tracker/reminder-settings	admin	Kontrak domain / handler	src/routes/auditFindingRoutes.js:10
POST	/api/audit-finding-tracker/reminder-settings/test	admin	body: to	src/routes/auditFindingRoutes.js:11

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/audit-finding-tracker	audit-finding-tracker:read	Kontrak domain / handler	src/routes/auditFindingRoutes.js:13
GET	/api/audit-finding-tracker/available-files	session; pemeriksaan tambahan di handler/service (lihat source)	Kontrak domain / handler	src/routes/auditFindingRoutes.js:14
GET	/api/audit-finding-tracker/:id/download	audit-finding-tracker:read	query: path; path: id	src/routes/auditFindingRoutes.js:19
POST	/api/audit-finding-tracker	audit-finding-tracker:create	body: kind, parentId	src/routes/auditFindingRoutes.js:23
PUT	/api/audit-finding-tracker/:id	audit-finding-tracker:update	body: kind; path: id	src/routes/auditFindingRoutes.js:24
DELETE	/api/audit-finding-tracker/:id	audit-finding-tracker:delete	path: id	src/routes/auditFindingRoutes.js:25

smtpRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/smtp-settings/accounts	admin	Kontrak domain / handler	src/routes/smtpRoutes.js:9
POST	/api/smtp-settings/accounts	admin	Kontrak domain / handler	src/routes/smtpRoutes.js:10
PUT	/api/smtp-settings/accounts/:id	admin	path: id	src/routes/smtpRoutes.js:11
GET	/api/smtp-settings	admin	Kontrak domain / handler	src/routes/smtpRoutes.js:12
PUT	/api/smtp-settings	admin	Kontrak domain / handler	src/routes/smtpRoutes.js:13
POST	/api/smtp-settings/test	admin	body: to, smtpAccountId	src/routes/smtpRoutes.js:14

assessmentRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/assessment	assessment:read	Kontrak domain / handler	src/routes/assessmentRoutes.js:6
PUT	/api/assessment	assessment:update	body: attachments	src/routes/assessmentRoutes.js:7
POST	/api/assessment/reset	assessment:delete	Kontrak domain / handler	src/routes/assessmentRoutes.js:8

fileRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/files	files:read	query: details	src/routes/fileRoutes.js:12
POST	/api/files	files:create	body: functionName, kind, rejectDuplicate	src/routes/fileRoutes.js:13
POST	/api/files/batch	files:create	body: functionName, kind, rejectDuplicate	src/routes/fileRoutes.js:14
GET	/api/files/access/*path	session; pemeriksaan tambahan di handler/service (lihat source)	path: path	src/routes/fileRoutes.js:16
GET	/api/files/open/*path	session; pemeriksaan tambahan di handler/service (lihat source)	path: path	src/routes/fileRoutes.js:17
GET	/api/files/open-page/*path	session; pemeriksaan tambahan di handler/service (lihat source)	path: path	src/routes/fileRoutes.js:18
PUT	/api/files/open-page/*path	session; pemeriksaan tambahan di handler/service (lihat source)	body: openPage; path: path	src/routes/fileRoutes.js:19
PUT	/api/files/*path	session; pemeriksaan tambahan di handler/service (lihat source)	path: path	src/routes/fileRoutes.js:20
GET	/api/files/*path	session; pemeriksaan tambahan di handler/service (lihat source)	path: path	src/routes/fileRoutes.js:25
DELETE	/api/files/*path	session; pemeriksaan tambahan di handler/service (lihat source)	query: library; path: path	src/routes/fileRoutes.js:26

storageRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/storage-settings	admin	Kontrak domain / handler	src/routes/storageRoutes.js:6
PUT	/api/storage-settings	admin	Kontrak domain / handler	src/routes/storageRoutes.js:7
POST	/api/storage-settings/test	admin	Kontrak domain / handler	src/routes/storageRoutes.js:8

csfRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/csf	csf:read	Kontrak domain / handler	src/routes/csfRoutes.js:7
POST	/api/csf	csf:create	Kontrak domain / handler	src/routes/csfRoutes.js:8
PUT	/api/csf/:id	csf:update	path: id	src/routes/csfRoutes.js:9
DELETE	/api/csf/:id	csf:delete	path: id	src/routes/csfRoutes.js:10

privacyRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/privacy	privacy:read	Kontrak domain / handler	src/routes/privacyRoutes.js:7
POST	/api/privacy	privacy:create	Kontrak domain / handler	src/routes/privacyRoutes.js:8
GET	/api/privacy/assessment	privacy-assessment:read	Kontrak domain / handler	src/routes/privacyRoutes.js:9
PUT	/api/privacy/assessment	privacy-assessment:update	body: attachments	src/routes/privacyRoutes.js:10
POST	/api/privacy/assessment/reset	privacy-assessment:delete	Kontrak domain / handler	src/routes/privacyRoutes.js:11
PUT	/api/privacy/:id	privacy:update	path: id	src/routes/privacyRoutes.js:12
DELETE	/api/privacy/:id	privacy:delete	path: id	src/routes/privacyRoutes.js:13

frameworkRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/frameworks	framework:read	Kontrak domain / handler	src/routes/frameworkRoutes.js:8
POST	/api/frameworks	framework:create	Kontrak domain / handler	src/routes/frameworkRoutes.js:9
GET	/api/frameworks/:frameworkId/controls	key framework/assessment dinamis:read	path: frameworkId	src/routes/frameworkRoutes.js:10
GET	/api/frameworks/:frameworkId/targets	key framework/assessment dinamis:read	path: frameworkId	src/routes/frameworkRoutes.js:11
PUT	/api/frameworks/:frameworkId/targets/:category	key framework/assessment dinamis:update	body: targetScore; path: frameworkId, category	src/routes/frameworkRoutes.js:12
GET	/api/frameworks/iso27001/objectives	iso27001:read	query: year	src/routes/frameworkRoutes.js:13
POST	/api/frameworks/iso27001/assessment/reset	iso27001:delete	Kontrak domain / handler	src/routes/frameworkRoutes.js:14
POST	/api/frameworks/iso27001/objectives	iso27001:create	Kontrak domain / handler	src/routes/frameworkRoutes.js:15
PUT	/api/frameworks/iso27001/objectives/:id	iso27001:update	path: id	src/routes/frameworkRoutes.js:16
DELETE	/api/frameworks/iso27001/objectives/:id	iso27001:delete	path: id	src/routes/frameworkRoutes.js:17
PUT	/api/frameworks/:frameworkId/controls/:code/evidence	framework / iso27001 / iso27001-soa:update	body: evidence; path: frameworkId, code	src/routes/frameworkRoutes.js:18
POST	/api/frameworks/:frameworkId/controls	key framework/assessment dinamis:create	path: frameworkId	src/routes/frameworkRoutes.js:19
PUT	/api/frameworks/:frameworkId/controls/:code	key framework/assessment dinamis:update	path: frameworkId, code	src/routes/frameworkRoutes.js:20

Method	Endpoint	Izin	Input terbaca	Source
DELETE	/api/frameworks/:frameworkId /controls/:code	key framework/assessment dinamis:delete	path: frameworkId, code	src/routes/frameworkRoutes.js:21

riskAcceptanceRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/risk-acceptance	risk-acceptance:read	Kontrak domain / handler	src/routes/riskAcceptanceRoutes.js:6
POST	/api/risk-acceptance	risk-acceptance:create	Kontrak domain / handler	src/routes/riskAcceptanceRoutes.js:7
GET	/api/risk-acceptance/:id/export/pdf	risk-acceptance:read	path: id	src/routes/riskAcceptanceRoutes.js:8
PUT	/api/risk-acceptance/:id	risk-acceptance:update	path: id	src/routes/riskAcceptanceRoutes.js:9
DELETE	/api/risk-acceptance/:id	risk-acceptance:delete	path: id	src/routes/riskAcceptanceRoutes.js:10

riskManagementRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/risk-management/dashboard	risk-management:read	Kontrak domain / handler	src/routes/riskManagementRoutes.js:5
GET	/api/risk-management/indicators	risk-management:read	Kontrak domain / handler	src/routes/riskManagementRoutes.js:6
GET	/api/risk-management/dropdowns	risk-management:read	Kontrak domain / handler	src/routes/riskManagementRoutes.js:7
POST	/api/risk-management/dropdowns	risk-management:create	Kontrak domain / handler	src/routes/riskManagementRoutes.js:8
PUT	/api/risk-management/dropdowns/:id	risk-management:update	path: id	src/routes/riskManagementRoutes.js:9

Method	Endpoint	Izin	Input terbaca	Source
DELETE	/api/risk-management/dropdowns/:id	risk-management:delete	path: id	src/routes/riskManagementRoutes.js:10
POST	/api/risk-management/indicators	risk-management:create	Kontrak domain / handler	src/routes/riskManagementRoutes.js:11
PUT	/api/risk-management/indicators/:id	risk-management:update	path: id	src/routes/riskManagementRoutes.js:12
DELETE	/api/risk-management/indicators/:id	risk-management:delete	path: id	src/routes/riskManagementRoutes.js:13
GET	/api/risk-management	risk-management:read	Kontrak domain / handler	src/routes/riskManagementRoutes.js:14
POST	/api/risk-management	risk-management:create	Kontrak domain / handler	src/routes/riskManagementRoutes.js:15
PUT	/api/risk-management/:id	risk-management:update	path: id	src/routes/riskManagementRoutes.js:16
DELETE	/api/risk-management/:id	risk-management:delete	path: id	src/routes/riskManagementRoutes.js:17
DELETE	/api/risk-management	risk-management:delete	Kontrak domain / handler	src/routes/riskManagementRoutes.js:18

personnelCertificationRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/personnel-certifications	personnel-certification:read	Kontrak domain / handler	src/routes/personnelCertificationRoutes.js:5
GET	/api/personnel-certifications/organization-personnel	personnel-certification:read	Kontrak domain / handler	src/routes/personnelCertificationRoutes.js:6
POST	/api/personnel-certifications/organization-personnel	personnel-certification:create	Kontrak domain / handler	src/routes/personnelCertificationRoutes.js:7

Method	Endpoint	Izin	Input terbaca	Source
PUT	/api/personnel-certifications/organization-personnel/:personnelId	personnel-certification:update	path: personnelId	src/routes/personnelCertificationRoutes.js:8
DELETE	/api/personnel-certifications/organization-personnel/:personnelId	personnel-certification:delete	path: personnelId	src/routes/personnelCertificationRoutes.js:9
POST	/api/personnel-certifications	personnel-certification:create	Kontrak domain / handler	src/routes/personnelCertificationRoutes.js:11
PUT	/api/personnel-certifications/:id/layout	personnel-certification:update	path: id	src/routes/personnelCertificationRoutes.js:12
PUT	/api/personnel-certifications/:id	personnel-certification:update	path: id	src/routes/personnelCertificationRoutes.js:13
DELETE	/api/personnel-certifications/:id	personnel-certification:delete	path: id	src/routes/personnelCertificationRoutes.js:14

certificationRoadmapCatalogRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/certification-roadmap-catalog	personnel-certification:read	Kontrak domain / handler	src/routes/certificationRoadmapCatalogRoutes.js:5
POST	/api/certification-roadmap-catalog	personnel-certification:create	Kontrak domain / handler	src/routes/certificationRoadmapCatalogRoutes.js:6
PUT	/api/certification-roadmap-catalog/:id	personnel-certification:update	path: id	src/routes/certificationRoadmapCatalogRoutes.js:7
DELETE	/api/certification-roadmap-catalog/:id	personnel-certification:delete	path: id	src/routes/certificationRoadmapCatalogRoutes.js:8

tprmRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/tprm	tprm-register:read	Kontrak domain / handler	src/routes/tprmRoutes.js:5
POST	/api/tprm	tprm-register:create	Kontrak domain / handler	src/routes/tprmRoutes.js:6
PUT	/api/tprm/:id	tprm-register:update	path: id	src/routes/tprmRoutes.js:7
DELETE	/api/tprm/:id	tprm-register:delete	path: id	src/routes/tprmRoutes.js:8

tprmQuestionnaireRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/tprm-questionnaires	tprm-questionnaire:read	Kontrak domain / handler	src/routes/tprmQuestionnaireRoutes.js:5
POST	/api/tprm-questionnaires	tprm-questionnaire:create	Kontrak domain / handler	src/routes/tprmQuestionnaireRoutes.js:6
PUT	/api/tprm-questionnaires/:id	tprm-questionnaire:update	path: id	src/routes/tprmQuestionnaireRoutes.js:7
PUT	/api/tprm-questionnaires/:id/documents	tprm-questionnaire:update	path: id	src/routes/tprmQuestionnaireRoutes.js:8
DELETE	/api/tprm-questionnaires/:id	tprm-questionnaire:delete	path: id	src/routes/tprmQuestionnaireRoutes.js:9

questionnaireTemplateRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/questionnaire-templates	questionnaire-templates:read	Kontrak domain / handler	src/routes/questionnaireTemplateRoutes.js:6
POST	/api/questionnaire-templates	questionnaire-templates:create	Kontrak domain / handler	src/routes/questionnaireTemplateRoutes.js:15
PUT	/api/questionnaire-templates/:id	questionnaire-templates:update	path: id	src/routes/questionnaireTemplateRoutes.js:24

Method	Endpoint	Izin	Input terbaca	Source
DELETE	/api/questionnaire-templates/:id	questionnaire-templates:delete	path: id	src/routes/questionnaireTemplateRoutes.js:33

policyRegisterRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/policy-register/reminder-settings	admin	Kontrak domain / handler	src/routes/policyRegisterRoutes.js:15
PUT	/api/policy-register/reminder-settings	admin	Kontrak domain / handler	src/routes/policyRegisterRoutes.js:16
POST	/api/policy-register/reminder-settings/test	admin	body: to	src/routes/policyRegisterRoutes.js:17
GET	/api/policy-register/dropdowns	policy-register:read	Kontrak domain / handler	src/routes/policyRegisterRoutes.js:25
POST	/api/policy-register/dropdowns	policy-register:create	Kontrak domain / handler	src/routes/policyRegisterRoutes.js:26
PUT	/api/policy-register/dropdowns/:id	policy-register:update	path: id	src/routes/policyRegisterRoutes.js:27
DELETE	/api/policy-register/dropdowns/:id	policy-register:delete	path: id	src/routes/policyRegisterRoutes.js:28
GET	/api/policy-register/:id/items	policy-register:read	path: id	src/routes/policyRegisterRoutes.js:30
POST	/api/policy-register/:id/items	policy-register:create	path: id	src/routes/policyRegisterRoutes.js:31
PUT	/api/policy-register/:id/items/:itemId	policy-register:update	path: id, itemId	src/routes/policyRegisterRoutes.js:32

Method	Endpoint	Izin	Input terbaca	Source
DELETE	/api/policy-register/:id/items/:itemId	policy-register:delete	path: id, itemId	src/routes/policyRegisterRoutes.js:33
GET	/api/policy-register	policy-register:read	Kontrak domain / handler	src/routes/policyRegisterRoutes.js:36
POST	/api/policy-register	policy-register:create	Kontrak domain / handler	src/routes/policyRegisterRoutes.js:51
PUT	/api/policy-register/:id	policy-register:update	path: id	src/routes/policyRegisterRoutes.js:59
DELETE	/api/policy-register/:id	policy-register:delete	path: id	src/routes/policyRegisterRoutes.js:67

auditRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/audit	admin	Kontrak domain / handler	src/routes/auditRoutes.js:6
POST	/api/audit/activity	session; pemeriksaan tambahan di handler/service (lihat source)	Kontrak domain / handler	src/routes/auditRoutes.js:11

backupRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/backups	admin	Kontrak domain / handler	src/routes/backupRoutes.js:7
POST	/api/backups	admin	Kontrak domain / handler	src/routes/backupRoutes.js:8
POST	/api/backups/restore	admin	Kontrak domain / handler	src/routes/backupRoutes.js:9
DELETE	/api/backups/:fileName	admin	path: fileName	src/routes/backupRoutes.js:10
GET	/api/backups/:fileName	admin	path: fileName	src/routes/backupRoutes.js:11

fileBackupRoutes

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/file-backups	admin	Kontrak domain / handler	src/routes/fileBackupRoutes.js:10
GET	/api/file-backups/folders	admin	Kontrak domain / handler	src/routes/fileBackupRoutes.js:11
POST	/api/file-backups	admin	body: folder	src/routes/fileBackupRoutes.js:12
POST	/api/file-backups/restore	admin	body: folder	src/routes/fileBackupRoutes.js:13
GET	/api/file-backups/:fileName	admin	path: fileName	src/routes/fileBackupRoutes.js:14
DELETE	/api/file-backups/:fileName	admin	path: fileName	src/routes/fileBackupRoutes.js:15

health

Method	Endpoint	Izin	Input terbaca	Source
GET	/api/health	session	Kontrak domain / handler	src/routes/index.js:25
GET	/api/health/db	session	Kontrak domain / handler	src/routes/index.js:25

Database, relasi, dan struktur data

Relasi data inti

Garis menunjukkan relasi inti; seluruh tabel dan migrasi dijelaskan di kamus data.



NIST Basis / BLACKOWL | Source workspace | 09-10-2026 | Tidak memuat data atau kredensial produksi

Model dan aturan integritas

PostgreSQL menjadi sumber data utama. Schema dasar berada di database/schema.sql; banyak modul menjalankan additive migrations dalam ensureStore. Inventaris di bawah berasal dari source, bukan koneksi schema produksi. DDL CREATE menunjukkan bentuk awal; ALTER dan trigger dalam source dapat menambahkan atau mengubah kolom/constraint.

Hubungan	Enforcement / penghapusan
framework -> controls/targets	Foreign key; lihat DDL untuk aksi cascade
organization_personnel -> personnel_certifications	FK dari migrasi; identitas sertifikasi berasal pegawai terdaftar
policy -> items / deliveries	FK pada store terkait
vendor questionnaire -> TPRM register	questionnaire_id FK ON DELETE SET NULL; create/update memvalidasi vendor cocok
TPRM -> risks	Join table tprm_related_risks, FK cascade kedua sisi; JSON legacy tetap ada
asset -> vendor TPRM	managed_vendor_id GENERATED STORED dari JSONB, FK DELETE RESTRICT; opsional null
asset -> racks	asset_id PK memastikan satu posisi; FK asset/rack DELETE RESTRICT
asset -> related risks	Join table FK CASCADE kedua sisi
asset relations	source/target FK RESTRICT, CHECK source!=target, UNIQUE source/target/type
asset/rack -> photos	FK CASCADE; original bytes dan evidence_path
evidence -> uploader	uploaded_by mengacu akun sesuai ownership migration; file legacy tanpa owner admin-only
audit hierarchy	self-FK parent_id RESTRICT; audit root tanpa parent, record anak punya parent
policy -> knowledge notes	related_note_ids JSONB; link logis, bukan FK individual
diagram -> assets	node IDs dalam JSONB; validasi service, bukan FK per node
evidence -> module attachments	Path di JSONB/record; diperiksa service dan cleanup/trigger, bukan seluruhnya FK

Normalisasi, JSONB, dan concurrency

Identitas core memakai PK UUID/BIGSERIAL/TEXT yang sesuai domain. Relasi penting memakai join table/FK; data formulir fleksibel memakai JSONB. managed_vendor_id mengubah referensi vendor dalam JSON aset menjadi kolom generated dengan FK, sehingga update/import JSON yang tidak valid ditolak database dan vendor yang masih dipakai tidak bisa dihapus. Index membantu lookup.

Rack occupancy divalidasi server di bawah advisory transaction lock. CHECK dasar/PK tidak sendirian membuktikan semua rentang U bebas overlap; operasi tulis aplikasi wajib melewati service. Asset diagram dan knowledge/threat model memakai optimistic versioning; mismatch mendapat 409.

Reset Risk Register sekarang memakai satu client pool dari BEGIN sampai COMMIT/ROLLBACK. Koneksi harus selalu release dalam finally. Mengirim BEGIN melalui pool.query lalu operasi melalui pool.query berbeda tidak menjamin transaksi satu koneksi.

Reference path foto/knowledge disinkronkan terhadap evidence_files lewat trigger penggantian/penghapusan. Content asli foto dan gambar knowledge tetap tersedia sebagai BYTEA; evidence umum di storage eksternal tidak selalu mempunyai salinan BYTEA. Kebijakan retensi library terpisah dari foto aktif.

Inventaris semua tabel dari source

Tabel	Definisi source
app_smtp_accounts	src/services/smtpService.js:52
app_smtp_settings	src/services/smtpService.js:44
app_users	database/users.sql:4
assessment_state	database/schema.sql:14
asset_diagram_layout	src/services/assetDiagramService.js:4
asset_rack_devices	src/services/assetManagementService.js:17
asset_racks	src/services/assetManagementService.js:16
asset_related_risks	src/services/assetManagementService.js:21
asset_relations	src/services/assetManagementService.js:20
asset_reminder_settings	src/services/assetReminderSettingsService.js:5
asset_renewal_deliveries	src/services/assetManagementService.js:22
audit_events	database/schema.sql:364; src/services/auditService.js:4
audit_finding_records	src/services/auditFindingService.js:27
audit_finding_reminder_deliveries	src/services/auditFindingReminderService.js:12
audit_finding_reminder_settings	src/services/auditFindingReminderService.js:11
certification_roadmap_catalog	database/schema.sql:160; src/services/certificationRoadmapCatalogService.js:33
controls	database/schema.sql:399
evidence_files	database/schema.sql:329
file_storage_locations	database/schema.sql:347; src/services/storageService.js:28

Tabel	Definisi source
file_storage_settings	database/schema.sql:338; src/services/storageService.js:25
framework_category_targets	database/schema.sql:438
frameworks	database/schema.sql:387
information_security_objectives	database/schema.sql:450
knowledge_note_folders	src/services/knowledgeNoteService.js:24
knowledge_note_images	src/services/knowledgeImageService.js:4
knowledge_notes	src/services/knowledgeNoteService.js:17
managed_assets	src/services/assetManagementService.js:10
organization_personnel	database/schema.sql:146; src/services/personnelCertificationService.js:38
personnel_certifications	database/schema.sql:118; src/services/personnelCertificationService.js:37
policy_register	database/schema.sql:205; src/services/policyRegisterService.js:94
policy_register_dropdown_options	database/schema.sql:238; src/services/policyRegisterService.js:125
policy_register_items	database/schema.sql:224; src/services/policyRegisterService.js:112
policy_reminder_deliveries	src/services/policyReminderService.js:19
policy_reminder_settings	src/services/policyReminderService.js:18
questionnaire_templates	database/schema.sql:274
risk_acceptance_forms	database/schema.sql:20; src/services/riskAcceptanceService.js:29
risk_dropdown_options	database/schema.sql:105; src/services/riskManagementService.js:39
risk_indicators	database/schema.sql:52; src/services/riskManagementService.js:35
risk_register	database/schema.sql:66; src/services/riskManagementService.js:36
role_permissions	database/schema.sql:516; src/services/permissionService.js:72
threat_models	database/schema.sql:5; src/services/threatModelService.js:40
tpm_due_diligence_questionnaires	database/schema.sql:287; src/services/tpmQuestionnaireService.js:10
tpm_related_risks	database/schema.sql:196; src/services/tpmService.js:14
tpm_risk_register	database/schema.sql:176; src/services/tpmService.js:14

Kolom, constraint, dan migrasi per tabel

Definisi berikut adalah kutipan DDL source untuk audit dan pemahaman, **bukan script migrasi yang boleh langsung dieksekusi**. Untuk instalasi gunakan provisioning/startup resmi.

app_smtp_accounts

Source: `src/services/smtpService.js:52` .

```
CREATE TABLE IF NOT EXISTS app_smtp_accounts (id UUID PRIMARY KEY, settings JSONB NOT NULL, secret TEXT NOT NULL DEFAULT '');
```

app_smtp_settings

Source: `src/services/smtpService.js:44` .

```
CREATE TABLE IF NOT EXISTS app_smtp_settings (id INTEGER PRIMARY KEY CHECK (id = 1), settings JSONB NOT NULL, secret TEXT NOT NULL DEFAULT '');
```

app_users

Source: `database/users.sql:4` .

```
CREATE TABLE IF NOT EXISTS app_users (  
  id BIGSERIAL PRIMARY KEY,  
  username TEXT UNIQUE NOT NULL,  
  full_name TEXT NOT NULL DEFAULT '',  
  password_hash TEXT NOT NULL,  
  role TEXT NOT NULL DEFAULT 'user' CHECK (role IN ('admin', 'approver', 'editor', 'viewer', 'user')),  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

Migrasi source terkait:

- `database/users.sql: ALTER TABLE app_users`

assessment_state

Source: `database/schema.sql:14` .

```
CREATE TABLE IF NOT EXISTS assessment_state (  
  id TEXT PRIMARY KEY,  
  data JSONB NOT NULL,  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

Migrasi source terkait:

- `database/schema.sql: ALTER TABLE assessment_state ADD CONSTRAINT assessment_state_id_not_blank CHECK (btrim(id) <> ')`

asset_diagram_layout

Source: `src/services/assetDiagramService.js:4` .

```
CREATE TABLE IF NOT EXISTS asset_diagram_layout (id INTEGER PRIMARY KEY CHECK(id=1), nodes JSONB NOT NULL, version INTEGER NOT NULL DEFAULT 1);
```

asset_rack_devices

Source: `src/services/assetManagementService.js:17` .

```
CREATE TABLE IF NOT EXISTS asset_rack_devices(asset_id UUID PRIMARY KEY REFERENCES managed_assets(id) ON DELETE RESTRICT, rack_id UUID NOT NULL  
REFERENCES asset_racks(id) ON DELETE RESTRICT, start_unit INTEGER NOT NULL, height INTEGER NOT NULL);
```

Migrasi source terkait:

- `src/services/assetManagementService.js: ALTER TABLE asset_rack_devices ADD COLUMN IF NOT EXISTS facing TEXT NOT NULL DEFAULT 'front' CHECK(facing IN ('front','rear`
- `src/services/assetManagementService.js: ALTER TABLE asset_rack_devices ADD COLUMN IF NOT EXISTS full_depth BOOLEAN NOT NULL DEFAULT TRUE`

asset_racks

Source: `src/services/assetManagementService.js:16` .

```
CREATE TABLE IF NOT EXISTS asset_racks(id UUID PRIMARY KEY, name TEXT UNIQUE NOT NULL, location TEXT NOT NULL, units INTEGER NOT NULL CHECK(units BETWEEN 1 AND 60));
```

asset_related_risks

Source: `src/services/assetManagementService.js:21` .

```
CREATE TABLE IF NOT EXISTS asset_related_risks(asset_id UUID NOT NULL REFERENCES managed_assets(id) ON DELETE CASCADE, risk_id TEXT NOT NULL REFERENCES risk_register(risk_id) ON DELETE CASCADE, PRIMARY KEY(asset_id,risk_id));
```

asset_relations

Source: `src/services/assetManagementService.js:20` .

```
CREATE TABLE IF NOT EXISTS asset_relations(id UUID PRIMARY KEY, source_id UUID NOT NULL REFERENCES managed_assets(id) ON DELETE RESTRICT, target_id UUID NOT NULL REFERENCES managed_assets(id) ON DELETE RESTRICT, type TEXT NOT NULL, notes TEXT NOT NULL DEFAULT '', change_reference TEXT NOT NULL, CHECK(source_id <> target_id), UNIQUE(source_id,target_id,type));
```

asset_reminder_settings

Source: `src/services/assetReminderSettingsService.js:5` .

```
CREATE TABLE IF NOT EXISTS asset_reminder_settings (id INTEGER PRIMARY KEY CHECK(id=1), settings JSONB NOT NULL);
```

asset_renewal_deliveries

Source: `src/services/assetManagementService.js:22` .

```
CREATE TABLE IF NOT EXISTS asset_renewal_deliveries(asset_id UUID REFERENCES managed_assets(id) ON DELETE CASCADE, renewal_date DATE NOT NULL, recipient TEXT NOT NULL, sent_on DATE NOT NULL, PRIMARY KEY(asset_id,renewal_date,recipient,sent_on));
```

audit_events

Source: `database/schema.sql:364` .

```
CREATE TABLE IF NOT EXISTS audit_events (  
  id BIGSERIAL PRIMARY KEY,  
  request_id TEXT NOT NULL,  
  actor_username TEXT NOT NULL DEFAULT '',  
  actor_role TEXT NOT NULL DEFAULT '',  
  event_type TEXT NOT NULL,  
  method TEXT NOT NULL,  
  path TEXT NOT NULL,  
  status_code INTEGER NOT NULL DEFAULT 200,  
  ip_address TEXT NOT NULL DEFAULT '',  
  user_agent TEXT NOT NULL DEFAULT '',  
  duration_ms INTEGER NOT NULL DEFAULT 0,  
  details JSONB NOT NULL DEFAULT '{} '::jsonb,  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

audit_finding_records

Source: `src/services/auditFindingService.js:27` .

```
CREATE TABLE IF NOT EXISTS audit_finding_records (  
  id UUID PRIMARY KEY, kind TEXT NOT NULL CHECK(kind IN ('audit','finding','followup','evidence')),  
  parent_id UUID REFERENCES audit_finding_records(id) ON DELETE RESTRICT,  
  data JSONB NOT NULL, filename TEXT, content BYTEA, created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), CHECK ((kind = 'audit') = (parent_id IS NULL))  
);
```

audit_finding_reminder_deliveries

Source: `src/services/auditFindingReminderService.js:12` .

```
CREATE TABLE IF NOT EXISTS audit_finding_reminder_deliveries (  
  finding_id UUID REFERENCES audit_finding_records(id) ON DELETE CASCADE,  
  due_date DATE NOT NULL, recipient TEXT NOT NULL, sent_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  PRIMARY KEY(finding_id,due_date,recipient));
```

Migrasi source terkait:

- `src/services/auditFindingReminderService.js`: ALTER TABLE audit_finding_reminder_deliveries ADD COLUMN IF NOT EXISTS reminder_date DATE
- `src/services/auditFindingReminderService.js`: ALTER TABLE audit_finding_reminder_deliveries ALTER COLUMN reminder_date SET NOT NULL
- `src/services/auditFindingReminderService.js`: ALTER TABLE audit_finding_reminder_deliveries DROP CONSTRAINT IF EXISTS audit_finding_reminder_deliveries_pkey
- `src/services/auditFindingReminderService.js`: ALTER TABLE audit_finding_reminder_deliveries ADD PRIMARY KEY(finding_id,due_date,recipient,reminder_date)

audit_finding_reminder_settings

Source: `src/services/auditFindingReminderService.js:11` .

```
CREATE TABLE IF NOT EXISTS audit_finding_reminder_settings (id INTEGER PRIMARY KEY CHECK(id=1), settings JSONB NOT NULL);
```

certification_roadmap_catalog

Source: database/schema.sql:160 .

```
CREATE TABLE IF NOT EXISTS certification_roadmap_catalog (  
  id BIGSERIAL PRIMARY KEY,  
  domain TEXT NOT NULL DEFAULT '',  
  certification_name TEXT NOT NULL,  
  issuer TEXT NOT NULL DEFAULT '',  
  reference_url TEXT NOT NULL DEFAULT '',  
  certification_level TEXT NOT NULL DEFAULT 'Intermediate',  
  notes TEXT NOT NULL DEFAULT '',  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  CONSTRAINT certification_roadmap_catalog_unique UNIQUE (certification_name)  
);
```

Source: src/services/certificationRoadmapCatalogService.js:33 .

```
CREATE TABLE IF NOT EXISTS certification_roadmap_catalog (id BIGSERIAL PRIMARY KEY, domain TEXT NOT NULL DEFAULT '', certification_name TEXT NOT  
NULL, issuer TEXT NOT NULL DEFAULT '', reference_url TEXT NOT NULL DEFAULT '', certification_level TEXT NOT NULL DEFAULT 'Intermediate', notes TEXT  
NOT NULL DEFAULT '', created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), CONSTRAINT  
certification_roadmap_catalog_unique UNIQUE (certification_name));
```

controls

Source: database/schema.sql:399 .

```
CREATE TABLE IF NOT EXISTS controls (
  id BIGSERIAL PRIMARY KEY,
  framework_id TEXT NOT NULL REFERENCES frameworks (id) ON DELETE CASCADE,
  code TEXT NOT NULL,
  function TEXT NOT NULL,
  category TEXT NOT NULL,
  subcategory TEXT NOT NULL,
  implementation TEXT NOT NULL DEFAULT '',
  "references" TEXT NOT NULL DEFAULT '',
  minimum_evidence TEXT NOT NULL DEFAULT '',
  notes TEXT NOT NULL DEFAULT '',
  evidence JSONB NOT NULL DEFAULT '[]'::jsonb,
  applicability TEXT NOT NULL DEFAULT 'Applicable',
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  CONSTRAINT controls_framework_code_unique UNIQUE (framework_id, code),
  CONSTRAINT controls_code_not_blank CHECK (btrim(code) <> '')
);
```

Migrasi source terkait:

- database/schema.sql: ALTER TABLE controls ADD COLUMN IF NOT EXISTS minimum_evidence TEXT NOT NULL DEFAULT ''
- database/schema.sql: ALTER TABLE controls ADD COLUMN IF NOT EXISTS notes TEXT NOT NULL DEFAULT ''
- database/schema.sql: ALTER TABLE controls ADD COLUMN IF NOT EXISTS evidence JSONB NOT NULL DEFAULT '[]'::jsonb
- database/schema.sql: ALTER TABLE controls ADD COLUMN IF NOT EXISTS applicability TEXT NOT NULL DEFAULT 'Applicable'

evidence_files

Source: database/schema.sql:329 .

```
CREATE TABLE IF NOT EXISTS evidence_files (
  path TEXT PRIMARY KEY,
  name TEXT NOT NULL,
  content BYTEA,
```

```

mime_type TEXT NOT NULL,
open_page INTEGER NOT NULL DEFAULT 1 CHECK (open_page >= 1),
updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

```

Migrasi source terkait:

- database/evidence-ownership.sql: ALTER TABLE evidence_files ADD COLUMN IF NOT EXISTS uploaded_by BIGINT REFERENCES app_users(id) ON DELETE SET NULL
- database/schema.sql: ALTER TABLE evidence_files
- database/schema.sql: ALTER TABLE evidence_files ADD COLUMN IF NOT EXISTS open_page INTEGER NOT NULL DEFAULT 1 CHECK (open_page >= 1)
- database/schema.sql: ALTER TABLE evidence_files ADD CONSTRAINT evidence_files_path_not_blank CHECK (btrim(path) <> ')
- database/schema.sql: ALTER TABLE evidence_files ADD CONSTRAINT evidence_files_name_not_blank CHECK (btrim(name) <> ')

file_storage_locations

Source: database/schema.sql:347 .

```

CREATE TABLE IF NOT EXISTS file_storage_locations (
  path TEXT PRIMARY KEY,
  root TEXT NOT NULL,
  object_key TEXT NOT NULL,
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

```

Source: src/services/storageService.js:28 .

```

CREATE TABLE IF NOT EXISTS file_storage_locations (
  path TEXT PRIMARY KEY, root TEXT NOT NULL, object_key TEXT NOT NULL,
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());

```

file_storage_settings

Source: database/schema.sql:338 .

```
CREATE TABLE IF NOT EXISTS file_storage_settings (  
  id INTEGER PRIMARY KEY CHECK (id = 1),  
  mode TEXT NOT NULL CHECK (mode IN ('local', 'shared')),  
  directory TEXT NOT NULL DEFAULT '',  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

Source: src/services/storageService.js:25 .

```
CREATE TABLE IF NOT EXISTS file_storage_settings (  
  id INTEGER PRIMARY KEY CHECK (id = 1), mode TEXT NOT NULL CHECK (mode IN ('local', 'shared')),  
  directory TEXT NOT NULL DEFAULT '', updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

Migrasi source terkait:

- src/services/storageService.js: ALTER TABLE file_storage_settings DROP CONSTRAINT IF EXISTS file_storage_settings_mode_check
- src/services/storageService.js: ALTER TABLE file_storage_settings ADD CONSTRAINT file_storage_settings_mode_check CHECK (mode IN ('local', 'shared', 's3', 'gcs'))
- src/services/storageService.js: ALTER TABLE file_storage_settings ADD COLUMN IF NOT EXISTS cloud_config JSONB NOT NULL DEFAULT '{}'::jsonb

framework_category_targets

Source: database/schema.sql:438 .

```
CREATE TABLE IF NOT EXISTS framework_category_targets (  
  framework_id TEXT NOT NULL REFERENCES frameworks (id) ON DELETE CASCADE,  
  category TEXT NOT NULL,  
  target_score NUMERIC(3,1) NOT NULL DEFAULT 3.0 CHECK (target_score >= 0 AND target_score <= 5),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  PRIMARY KEY (framework_id, category),
```

```
CONSTRAINT framework_category_targets_category_not_blank CHECK (btrim(category) <> '')
);
```

frameworks

Source: database/schema.sql:387 .

```
CREATE TABLE IF NOT EXISTS frameworks (
  id TEXT PRIMARY KEY,
  name TEXT NOT NULL,
  version TEXT NOT NULL,
  description TEXT NOT NULL DEFAULT '',
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  CONSTRAINT frameworks_id_not_blank CHECK (btrim(id) <> ''),
  CONSTRAINT frameworks_name_not_blank CHECK (btrim(name) <> ''),
  CONSTRAINT frameworks_version_not_blank CHECK (btrim(version) <> '')
);
```

information_security_objectives

Source: database/schema.sql:450 .

```
CREATE TABLE IF NOT EXISTS information_security_objectives (
  id BIGSERIAL PRIMARY KEY,
  objective_year INTEGER NOT NULL CHECK (objective_year BETWEEN 2000 AND 2100),
  objective TEXT NOT NULL,
  indicator TEXT NOT NULL DEFAULT '',
  baseline TEXT NOT NULL DEFAULT '',
  target_value TEXT NOT NULL DEFAULT '',
  owner TEXT NOT NULL DEFAULT '',
  evaluation_frequency TEXT NOT NULL DEFAULT 'monthly' CHECK (evaluation_frequency IN ('monthly', 'quarterly', 'semester', 'annual')),
  period_targets JSONB NOT NULL DEFAULT '{} '::jsonb,
```

```

monthly_status TEXT NOT NULL DEFAULT 'Not started',
quarterly_status TEXT NOT NULL DEFAULT 'Not started',
semester_status TEXT NOT NULL DEFAULT 'Not started',
annual_status TEXT NOT NULL DEFAULT 'Not started',
notes TEXT NOT NULL DEFAULT '',
created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
CONSTRAINT information_security_objective_text_not_blank CHECK (btrim(objective) <> '')
);

```

Migrasi source terkait:

- `database/schema.sql: ALTER TABLE information_security_objectives`

knowledge_note_folders

Source: `src/services/knowledgeNoteService.js:24` .

```

CREATE TABLE IF NOT EXISTS knowledge_note_folders (path TEXT PRIMARY KEY);

```

knowledge_note_images

Source: `src/services/knowledgeImageService.js:4` .

```

CREATE TABLE IF NOT EXISTS knowledge_note_images (
  id UUID PRIMARY KEY,path TEXT NOT NULL UNIQUE,folder TEXT NOT NULL DEFAULT '',mime_type TEXT NOT NULL,
  content BYTEA NOT NULL,created_at TIMESTAMPTZ NOT NULL DEFAULT NOW());

```

Migrasi source terkait:

- `src/services/knowledgeImageService.js: ALTER TABLE knowledge_note_images ADD COLUMN IF NOT EXISTS evidence_path TEXT`

knowledge_notes

Source: `src/services/knowledgeNoteService.js:17` .

```
CREATE TABLE IF NOT EXISTS knowledge_notes (id BIGSERIAL PRIMARY KEY, title TEXT NOT NULL, content TEXT NOT NULL DEFAULT '', version INTEGER NOT NULL DEFAULT 1, updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

Migrasi source terkait:

- `src/services/knowledgeNoteService.js: ALTER TABLE knowledge_notes ADD COLUMN IF NOT EXISTS folder TEXT NOT NULL DEFAULT ''`

managed_assets

Source: `src/services/assetManagementService.js:10` .

```
CREATE TABLE IF NOT EXISTS managed_assets(id UUID PRIMARY KEY, tag TEXT UNIQUE NOT NULL, data JSONB NOT NULL, updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

Migrasi source terkait:

- `src/services/assetManagementService.js: ALTER TABLE managed_assets ADD COLUMN IF NOT EXISTS created_at TIMESTAMPTZ`
- `src/services/assetManagementService.js: ALTER TABLE managed_assets ALTER COLUMN created_at SET DEFAULT NOW(), ALTER COLUMN created_at SET NOT NULL`
- `src/services/assetManagementService.js: ALTER TABLE managed_assets ADD COLUMN IF NOT EXISTS managed_vendor_id BIGINT GENERATED ALWAYS AS (NULLIF(data->>'managedVendorId', '))`

organization_personnel

Source: `database/schema.sql:146` .

```
CREATE TABLE IF NOT EXISTS organization_personnel (  
  id BIGSERIAL PRIMARY KEY,  
  personnel_name TEXT NOT NULL,  
  employee_id TEXT NOT NULL DEFAULT '',  
  personnel_role TEXT NOT NULL DEFAULT '',  
  supervisor_name TEXT NOT NULL DEFAULT '',  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
```

```
updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
CONSTRAINT organization_personnel_name_not_blank CHECK (btrim(personnel_name) <> '')  
);
```

Source: `src/services/personnelCertificationService.js:38` .

```
CREATE TABLE IF NOT EXISTS organization_personnel (id BIGSERIAL PRIMARY KEY, personnel_name TEXT NOT NULL, employee_id TEXT NOT NULL DEFAULT '',  
personnel_role TEXT NOT NULL DEFAULT '', supervisor_name TEXT NOT NULL DEFAULT '', created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), updated_at  
TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

personnel_certifications

Source: `database/schema.sql:118` .

```
CREATE TABLE IF NOT EXISTS personnel_certifications (  
  id BIGSERIAL PRIMARY KEY,  
  -- Backfilled, constrained and indexed by personnel-certification-links.sql during setup.  
  personnel_id BIGINT,  
  personnel_name TEXT NOT NULL,  
  employee_id TEXT NOT NULL DEFAULT '',  
  personnel_role TEXT NOT NULL DEFAULT '',  
  supervisor_name TEXT NOT NULL DEFAULT '',  
  certification_name TEXT NOT NULL,  
  issuer TEXT NOT NULL DEFAULT '',  
  reference_url TEXT NOT NULL DEFAULT '',  
  certification_level TEXT NOT NULL DEFAULT 'Intermediate',  
  status TEXT NOT NULL DEFAULT 'Planned',  
  issue_date DATE,  
  expiry_date DATE,  
  notes TEXT NOT NULL DEFAULT '',  
  on_canvas BOOLEAN NOT NULL DEFAULT FALSE,  
  position_x INTEGER NOT NULL DEFAULT 24,  
  position_y INTEGER NOT NULL DEFAULT 24,  
  card_width INTEGER NOT NULL DEFAULT 260,
```

```
card_height INTEGER NOT NULL DEFAULT 190,  
created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

Source: `src/services/personnelCertificationService.js:37` .

```
CREATE TABLE IF NOT EXISTS personnel_certifications (id BIGSERIAL PRIMARY KEY, personnel_name TEXT NOT NULL, employee_id TEXT NOT NULL DEFAULT '',  
personnel_role TEXT NOT NULL DEFAULT '', supervisor_name TEXT NOT NULL DEFAULT '', certification_name TEXT NOT NULL, issuer TEXT NOT NULL DEFAULT '',  
reference_url TEXT NOT NULL DEFAULT '', certification_level TEXT NOT NULL DEFAULT 'Intermediate', status TEXT NOT NULL DEFAULT 'Planned', issue_date  
DATE, expiry_date DATE, notes TEXT NOT NULL DEFAULT '', on_canvas BOOLEAN NOT NULL DEFAULT FALSE, position_x INTEGER NOT NULL DEFAULT 24, position_y  
INTEGER NOT NULL DEFAULT 24, card_width INTEGER NOT NULL DEFAULT 260, card_height INTEGER NOT NULL DEFAULT 190, created_at TIMESTAMPTZ NOT NULL  
DEFAULT NOW(), updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

Migrasi source terkait:

- `database/personnel-certification-links.sql: ALTER TABLE personnel_certifications ADD COLUMN IF NOT EXISTS personnel_id BIGINT`
- `database/personnel-certification-links.sql: ALTER TABLE personnel_certifications`
- `database/personnel-certification-links.sql: ALTER TABLE personnel_certifications ALTER COLUMN personnel_id SET NOT NULL`
- `src/services/personnelCertificationService.js: ALTER TABLE personnel_certifications ADD COLUMN IF NOT EXISTS reference_url TEXT NOT NULL DEFAULT ''`
- `src/services/personnelCertificationService.js: ALTER TABLE personnel_certifications ADD COLUMN IF NOT EXISTS certification_level TEXT NOT NULL DEFAULT 'Intermediate'`
- `src/services/personnelCertificationService.js: ALTER TABLE personnel_certifications ADD COLUMN IF NOT EXISTS on_canvas BOOLEAN NOT NULL DEFAULT FALSE`
- `src/services/personnelCertificationService.js: ALTER TABLE personnel_certifications ADD COLUMN IF NOT EXISTS supervisor_name TEXT NOT NULL DEFAULT ''`

policy_register

Source: `database/schema.sql:205` .

```
CREATE TABLE IF NOT EXISTS policy_register (  
  id BIGSERIAL PRIMARY KEY,  
  title TEXT NOT NULL,  
  category TEXT NOT NULL,  
  owner TEXT NOT NULL,  
  review_cycle TEXT NOT NULL,  
  approval_status TEXT NOT NULL,  
  last_review DATE,  
  attachment_name TEXT NOT NULL DEFAULT '',  
  attachment_path TEXT NOT NULL DEFAULT '',  
  attachment_type TEXT NOT NULL DEFAULT '',  
  notes TEXT NOT NULL DEFAULT '',  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

Migrasi source terkait:

- `src/services/policyRegisterService.js`: `ALTER TABLE policy_register ADD COLUMN IF NOT EXISTS related_note_ids JSONB NOT NULL DEFAULT '[]'::jsonb`

policy_register_dropdown_options

Source: `database/schema.sql:238` .

```
CREATE TABLE IF NOT EXISTS policy_register_dropdown_options (  
  id BIGSERIAL PRIMARY KEY,  
  field_name TEXT NOT NULL,  
  option_value TEXT NOT NULL,  
  sort_order INTEGER NOT NULL DEFAULT 0,  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  CONSTRAINT policy_register_dropdown_option_unique UNIQUE (field_name, option_value)  
);
```

policy_register_items

Source: database/schema.sql:224 .

```
CREATE TABLE IF NOT EXISTS policy_register_items (  
  id BIGSERIAL PRIMARY KEY,  
  policy_id BIGINT NOT NULL REFERENCES policy_register(id) ON DELETE CASCADE,  
  subtitle TEXT NOT NULL DEFAULT '',  
  content TEXT NOT NULL DEFAULT '',  
  sort_order INTEGER NOT NULL DEFAULT 0,  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  CONSTRAINT policy_register_item_content_check CHECK (subtitle <> '' OR content <> '')  
);
```

policy_reminder_deliveries

Source: src/services/policyReminderService.js:19 .

```
CREATE TABLE IF NOT EXISTS policy_reminder_deliveries (policy_id BIGINT REFERENCES policy_register(id) ON DELETE CASCADE, due_date DATE NOT NULL,  
recipient TEXT NOT NULL, sent_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), PRIMARY KEY(policy_id, due_date, recipient));
```

Migrasi source terkait:

- src/services/policyReminderService.js: ALTER TABLE policy_reminder_deliveries ADD COLUMN IF NOT EXISTS reminder_date DATE
- src/services/policyReminderService.js: ALTER TABLE policy_reminder_deliveries ALTER COLUMN reminder_date SET NOT NULL
- src/services/policyReminderService.js: ALTER TABLE policy_reminder_deliveries DROP CONSTRAINT IF EXISTS policy_reminder_deliveries_pkey
- src/services/policyReminderService.js: ALTER TABLE policy_reminder_deliveries ADD PRIMARY KEY(policy_id,due_date,recipient,reminder_date)

policy_reminder_settings

Source: src/services/policyReminderService.js:18 .

```
CREATE TABLE IF NOT EXISTS policy_reminder_settings (id INTEGER PRIMARY KEY CHECK (id = 1), settings JSONB NOT NULL, secret TEXT NOT NULL DEFAULT '');
```

questionnaire_templates

Source: database/schema.sql:274 .

```
CREATE TABLE IF NOT EXISTS questionnaire_templates (  
  id BIGSERIAL PRIMARY KEY,  
  template_name TEXT NOT NULL UNIQUE,  
  description TEXT NOT NULL DEFAULT '',  
  sections JSONB NOT NULL DEFAULT '[]'::jsonb,  
  is_default BOOLEAN NOT NULL DEFAULT FALSE,  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

risk_acceptance_forms

Source: database/schema.sql:20 .

```
CREATE TABLE IF NOT EXISTS risk_acceptance_forms (  
  id BIGSERIAL PRIMARY KEY,  
  requestor_name TEXT NOT NULL,  
  asset_name TEXT NOT NULL,  
  department TEXT NOT NULL,  
  previously_accepted BOOLEAN NOT NULL DEFAULT FALSE,  
  risk_description TEXT NOT NULL,  
  benefit_justification TEXT NOT NULL,  
  mitigation_plan TEXT NOT NULL,  
  business_owner_decision TEXT NOT NULL CHECK (business_owner_decision IN ('temporary', 'one_year', 'denied')),  
  remediation_date DATE,
```

```

requestor_print_name TEXT NOT NULL DEFAULT '',
requestor_email_phone TEXT NOT NULL DEFAULT '',
requestor_signature TEXT NOT NULL DEFAULT '',
requestor_date DATE,
cio_comments TEXT NOT NULL DEFAULT '',
cio_name TEXT NOT NULL DEFAULT '',
cio_signature TEXT NOT NULL DEFAULT '',
cio_date DATE,
cis_decision TEXT NOT NULL CHECK (cis_decision IN ('approved', 'denied', 'conditional')),
cis_reason TEXT NOT NULL DEFAULT '',
cis_conditions TEXT NOT NULL DEFAULT '',
cis_name TEXT NOT NULL DEFAULT '',
cis_signature TEXT NOT NULL DEFAULT '',
cis_date DATE,
created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

```

Source: `src/services/riskAcceptanceService.js:29` .

```

CREATE TABLE IF NOT EXISTS risk_acceptance_forms (id BIGSERIAL PRIMARY KEY, requestor_name TEXT NOT NULL, asset_name TEXT NOT NULL, department TEXT NOT NULL, previously_accepted BOOLEAN NOT NULL DEFAULT FALSE, risk_description TEXT NOT NULL, benefit_justification TEXT NOT NULL, mitigation_plan TEXT NOT NULL, business_owner_decision TEXT NOT NULL CHECK (business_owner_decision IN ('temporary', 'one_year', 'denied')), remediation_date DATE, requestor_print_name TEXT NOT NULL DEFAULT '', requestor_email_phone TEXT NOT NULL DEFAULT '', requestor_signature TEXT NOT NULL DEFAULT '', requestor_date DATE, cio_comments TEXT NOT NULL DEFAULT '', cio_name TEXT NOT NULL DEFAULT '', cio_signature TEXT NOT NULL DEFAULT '', cio_date DATE, cis_decision TEXT NOT NULL CHECK (cis_decision IN ('approved', 'denied', 'conditional')), cis_reason TEXT NOT NULL DEFAULT '', cis_conditions TEXT NOT NULL DEFAULT '', cis_name TEXT NOT NULL DEFAULT '', cis_signature TEXT NOT NULL DEFAULT '', cis_date DATE, created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());

```

risk_dropdown_options

Source: `database/schema.sql:105` .

```
CREATE TABLE IF NOT EXISTS risk_dropdown_options (  
  id BIGSERIAL PRIMARY KEY,  
  field_name TEXT NOT NULL,  
  option_value TEXT NOT NULL,  
  sort_order INTEGER NOT NULL DEFAULT 0,  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  CONSTRAINT risk_dropdown_option_unique UNIQUE (field_name, option_value)  
);
```

Source: `src/services/riskManagementService.js:39`.

```
CREATE TABLE IF NOT EXISTS risk_dropdown_options (id BIGSERIAL PRIMARY KEY, field_name TEXT NOT NULL, option_value TEXT NOT NULL, sort_order INTEGER  
NOT NULL DEFAULT 0, created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), CONSTRAINT  
risk_dropdown_option_unique UNIQUE (field_name, option_value));
```

risk_indicators

Source: `database/schema.sql:52`.

```
CREATE TABLE IF NOT EXISTS risk_indicators (  
  id BIGSERIAL PRIMARY KEY,  
  indicator_type TEXT NOT NULL,  
  score INTEGER,  
  label TEXT NOT NULL,  
  description TEXT NOT NULL DEFAULT '',  
  details JSONB NOT NULL DEFAULT '{}'::jsonb,  
  sort_order INTEGER NOT NULL DEFAULT 0,  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

Source: `src/services/riskManagementService.js:35`.

```
CREATE TABLE IF NOT EXISTS risk_indicators (id BIGSERIAL PRIMARY KEY, indicator_type TEXT NOT NULL, score INTEGER, label TEXT NOT NULL, description TEXT NOT NULL DEFAULT '', details JSONB NOT NULL DEFAULT '{}':::jsonb, sort_order INTEGER NOT NULL DEFAULT 0, updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

risk_register

Source: `database/schema.sql:66` .

```
CREATE TABLE IF NOT EXISTS risk_register (  
    risk_id TEXT PRIMARY KEY,  
    third_party TEXT NOT NULL DEFAULT '',  
    risk_category TEXT NOT NULL,  
    effected_asset TEXT NOT NULL,  
    device_name TEXT NOT NULL DEFAULT '',  
    identification_risk TEXT NOT NULL,  
    risk_control TEXT NOT NULL DEFAULT '',  
    risk_cause TEXT NOT NULL DEFAULT '',  
    risk_analysis TEXT NOT NULL DEFAULT '',  
    asset_confidentiality INTEGER,  
    asset_integrity INTEGER,  
    asset_availability INTEGER,  
    asset_value INTEGER,  
    risk_owner TEXT NOT NULL DEFAULT '',  
    note TEXT NOT NULL DEFAULT '',  
    ref TEXT NOT NULL DEFAULT '',  
    likelihood INTEGER NOT NULL,  
    impact INTEGER NOT NULL,  
    risk_rating TEXT NOT NULL DEFAULT '',  
    treatment_action TEXT NOT NULL DEFAULT '',  
    acceptance_form_no TEXT NOT NULL DEFAULT '',  
    risk_treatment_description TEXT NOT NULL DEFAULT '',  
    owner_of_action TEXT NOT NULL DEFAULT '',  
    deadline DATE,  
    residual_risk_description TEXT NOT NULL DEFAULT '',
```

```

residual_likelihood INTEGER,
residual_impact INTEGER,
residual_rating TEXT NOT NULL DEFAULT '',
comment TEXT NOT NULL DEFAULT '',
created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);

```

Source: `src/services/riskManagementService.js:36` .

```

CREATE TABLE IF NOT EXISTS risk_register (risk_id TEXT PRIMARY KEY, risk_category TEXT NOT NULL, effected_asset TEXT NOT NULL, device_name TEXT NOT NULL DEFAULT '', identification_risk TEXT NOT NULL, risk_control TEXT NOT NULL DEFAULT '', risk_cause TEXT NOT NULL DEFAULT '', risk_analysis TEXT NOT NULL DEFAULT '', asset_confidentiality INTEGER, asset_integrity INTEGER, asset_availability INTEGER, asset_value INTEGER, risk_owner TEXT NOT NULL DEFAULT '', note TEXT NOT NULL DEFAULT '', ref TEXT NOT NULL DEFAULT '', likelihood INTEGER NOT NULL, impact INTEGER NOT NULL, risk_rating TEXT NOT NULL DEFAULT '', treatment_action TEXT NOT NULL DEFAULT '', acceptance_form_no TEXT NOT NULL DEFAULT '', risk_treatment_description TEXT NOT NULL DEFAULT '', owner_of_action TEXT NOT NULL DEFAULT '', deadline DATE, residual_risk_description TEXT NOT NULL DEFAULT '', residual_likelihood INTEGER, residual_impact INTEGER, residual_rating TEXT NOT NULL DEFAULT '', comment TEXT NOT NULL DEFAULT '', created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());

```

Migrasi source terkait:

- `database/schema.sql: ALTER TABLE risk_register ADD COLUMN IF NOT EXISTS third_party TEXT NOT NULL DEFAULT ''`
- `src/services/riskManagementService.js: ALTER TABLE risk_register ADD COLUMN IF NOT EXISTS device_name TEXT NOT NULL DEFAULT ''`
- `src/services/riskManagementService.js: ALTER TABLE risk_register ADD COLUMN IF NOT EXISTS third_party TEXT NOT NULL DEFAULT ''`

role_permissions

Source: `database/schema.sql:516` .

```

CREATE TABLE IF NOT EXISTS role_permissions (
  role TEXT NOT NULL CHECK (role IN ('admin', 'user')),
  permission_key TEXT NOT NULL,
  allowed BOOLEAN NOT NULL DEFAULT TRUE,
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),

```

```
PRIMARY KEY (role, permission_key)
);
```

Source: `src/services/permissionService.js:72` .

```
CREATE TABLE IF NOT EXISTS role_permissions (role TEXT NOT NULL CHECK (role IN ('admin', 'approver', 'editor', 'viewer', 'user')), permission_key
TEXT NOT NULL, allowed BOOLEAN NOT NULL DEFAULT TRUE, updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), PRIMARY KEY (role, permission_key));
```

Migrasi source terkait:

- `src/services/permissionService.js: ALTER TABLE role_permissions ADD COLUMN IF NOT EXISTS actions JSONB`
- `src/services/permissionService.js: ALTER TABLE role_permissions DROP CONSTRAINT IF EXISTS role_permissions_role_check`
- `src/services/permissionService.js: ALTER TABLE role_permissions ADD CONSTRAINT role_permissions_role_check CHECK (role IN ('admin', 'approver', 'editor', 'viewer', 'user`

threat_models

Source: `database/schema.sql:5` .

```
CREATE TABLE IF NOT EXISTS threat_models (
  id BIGSERIAL PRIMARY KEY,
  name TEXT NOT NULL,
  diagram JSONB NOT NULL,
  version INTEGER NOT NULL DEFAULT 1,
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()
);
```

Source: `src/services/threatModelService.js:40` .

```
CREATE TABLE IF NOT EXISTS threat_models (id BIGSERIAL PRIMARY KEY, name TEXT NOT NULL, diagram JSONB NOT NULL, version INTEGER NOT NULL DEFAULT 1,
created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

tprm_due_diligence_questionnaires

Source: database/schema.sql:287 .

```
CREATE TABLE IF NOT EXISTS tprm_due_diligence_questionnaires (  
  id BIGSERIAL PRIMARY KEY,  
  vendor_name TEXT NOT NULL,  
  template_id BIGINT,  
  assessment_status TEXT NOT NULL DEFAULT 'Draft',  
  review_date DATE,  
  assessment_result TEXT NOT NULL DEFAULT 'Pending',  
  reviewer TEXT NOT NULL DEFAULT '',  
  notes TEXT NOT NULL DEFAULT '',  
  responses JSONB NOT NULL DEFAULT '{}'::jsonb,  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

Source: src/services/tprmQuestionnaireService.js:10 .

```
CREATE TABLE IF NOT EXISTS tprm_due_diligence_questionnaires (id BIGSERIAL PRIMARY KEY, vendor_name TEXT NOT NULL, assessment_status TEXT NOT NULL  
DEFAULT 'Draft', review_date DATE, assessment_result TEXT NOT NULL DEFAULT 'Pending', reviewer TEXT NOT NULL DEFAULT '', notes TEXT NOT NULL DEFAULT  
'', responses JSONB NOT NULL DEFAULT '{}'::jsonb, created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(), updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

Migrasi source terkait:

- src/services/tprmQuestionnaireService.js: ALTER TABLE tprm_due_diligence_questionnaires ADD COLUMN IF NOT EXISTS responses JSONB NOT NULL DEFAULT '{}'::jsonb

tprm_related_risks

Source: database/schema.sql:196 .

```
CREATE TABLE IF NOT EXISTS tprm_related_risks (  
  tprm_id BIGINT NOT NULL REFERENCES tprm_risk_register(id) ON DELETE CASCADE,  
  risk_id TEXT NOT NULL REFERENCES risk_register(risk_id) ON DELETE CASCADE,  
  PRIMARY KEY (tprm_id, risk_id)  
);
```

Source: `src/services/tprmService.js:14`.

```
CREATE TABLE IF NOT EXISTS tprm_related_risks (tprm_id BIGINT NOT NULL REFERENCES tprm_risk_register(id) ON DELETE CASCADE, risk_id TEXT NOT NULL  
REFERENCES risk_register(risk_id) ON DELETE CASCADE, PRIMARY KEY (tprm_id, risk_id));
```

tprm_risk_register

Source: `database/schema.sql:176`.

```
CREATE TABLE IF NOT EXISTS tprm_risk_register (  
  id BIGSERIAL PRIMARY KEY,  
  third_party TEXT NOT NULL,  
  service_dependency TEXT NOT NULL,  
  risk_level TEXT NOT NULL,  
  assessment_status TEXT NOT NULL DEFAULT 'Not started',  
  relationship_status TEXT NOT NULL DEFAULT 'Active',  
  next_review DATE,  
  notes TEXT NOT NULL DEFAULT '',  
  risk_register_ids JSONB NOT NULL DEFAULT '[]'::jsonb,  
  created_at TIMESTAMPTZ NOT NULL DEFAULT NOW(),  
  updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW()  
);
```

Source: `src/services/tprmService.js:14`.

```
CREATE TABLE IF NOT EXISTS tprm_risk_register (id BIGSERIAL PRIMARY KEY, third_party TEXT NOT NULL, service_dependency TEXT NOT NULL, risk_level TEXT  
NOT NULL DEFAULT 'Medium Risk (Tier 2)', assessment_status TEXT NOT NULL DEFAULT 'Not started', relationship_status TEXT NOT NULL DEFAULT 'Active',
```

```
next_review DATE, notes TEXT NOT NULL DEFAULT '', risk_register_ids JSONB NOT NULL DEFAULT '[]'::jsonb, questionnaire_id BIGINT REFERENCES
tprm_due_diligence_questionnaires(id) ON DELETE SET NULL, due_diligence_assessment JSONB NOT NULL DEFAULT '{}'::jsonb, created_at TIMESTAMPTZ NOT
NULL DEFAULT NOW(), updated_at TIMESTAMPTZ NOT NULL DEFAULT NOW());
```

Migrasi source terkait:

- database/schema.sql: ALTER TABLE tprm_risk_register ADD COLUMN IF NOT EXISTS risk_register_ids JSONB NOT NULL DEFAULT '[]'::jsonb
- database/schema.sql: ALTER TABLE tprm_risk_register ADD COLUMN IF NOT EXISTS relationship_status TEXT NOT NULL DEFAULT 'Active'
- database/schema.sql: ALTER TABLE tprm_risk_register
- src/services/tprmService.js: ALTER TABLE tprm_risk_register ADD COLUMN IF NOT EXISTS questionnaire_id BIGINT REFERENCES tprm_due_diligence_questionnaires(id) ON DELETE SET NULL
- src/services/tprmService.js: ALTER TABLE tprm_risk_register ADD COLUMN IF NOT EXISTS due_diligence_assessment JSONB NOT NULL DEFAULT '{}'::jsonb
- src/services/tprmService.js: ALTER TABLE tprm_risk_register ADD COLUMN IF NOT EXISTS risk_register_ids JSONB NOT NULL DEFAULT '[]'::jsonb
- src/services/tprmService.js: ALTER TABLE tprm_risk_register ADD COLUMN IF NOT EXISTS relationship_status TEXT NOT NULL DEFAULT 'Active'

Batas dan pengembangan relasi

Policy-note, node diagram, dan beberapa attachment masih memakai link logis/JSONB. Rekomendasi berikutnya adalah normalisasi link yang membutuhkan jaminan database, disertai backfill dan tes orphan/cascade. Jangan menerapkan FK terhadap data legacy tanpa pemeriksaan referensi. Tenancy dan isolasi per organisasi belum tersedia; RLS tenant bukan kontrol yang sudah aktif.

Review keamanan dan praktik industri

Tanggal: 9 Oktober 2026. Scope: source aplikasi, dependency audit npm, relasi vendor aset, transaksi reset risiko, konfigurasi build, dan pengujian regresi. Ini bukan sertifikat kepatuhan, pentest deployment, atau jaminan bebas semua kerentanan.

Temuan dan perubahan pada pemeriksaan ini

Temuan	Penanganan	Bukti
Advisory Vue/server-renderer, proxy-addr, source-map-js	npm audit fix kompatibel; minimum Vue dinaikkan ^3.5.42; lockfile diperbarui	output/security-audit-2026-10-09-before.json dan after.json
Penyimpanan vendor dan linked risks belum atomik	Create/update TPRM memakai satu client dan transaksi; kegagalan relasi membatalkan perubahan vendor	test/databaseIntegrityHardening.test.js
Reset register memakai pool.query BEGIN terpisah	Satu client checkout dipakai untuk seluruh transaksi; rollback/release	test/databaseIntegrityHardening.test.js
Vendor pengelola aset hanya ID di JSONB	Kolom generated managed_vendor_id dengan FK RESTRICT dan index; vendor opsional tetap null	src/services/assetManagementService.js
Delete vendor ber-FK dapat memberi error internal	Constraint conflict menjadi 409 dengan instruksi lepaskan relasi	src/services/tprmService.js
Potensi injeksi atribut class dari status sertifikasi legacy	Token class dibatasi a-z/0-9/underscore/hyphen; berlaku juga pada rating risiko dan vendor	test/databaseIntegrityHardening.test.js
Source map frontend tersedia pada build	sourcemap false; generated build tidak menerbitkan .map	frontend/client/vite.config.js

Audit dependency setelah update melaporkan **0 advisory npm** pada lockfile saat pemeriksaan. Status ini hanya cakupan advisory yang dilaporkan npm, bukan bukti seluruh kode aman. Vue SSR tidak digunakan sebagai arsitektur runtime aplikasi ini; patch tetap diterapkan terhadap paket terpasang. Proxy trust pada app belum diaktifkan, tetapi paket rentan tetap diperbarui.

Referensi advisory: Vue, proxy-addr, source-map-js. Detail applicability perlu dibedakan dari severity paket; tidak diklaim terjadi exploit pada deployment pengguna.

Kontrol keamanan yang sudah ada

Area	Implementasi	Batas
Authentication	Bcrypt, token random32 byte, cookie HttpOnly/SameSite, lifetime8 jam, invalidasi sesi	In-memory per proses; belum SSO/MFA
Authorization	Guard backend Read/Create/Update/Delete, admin-only, ownership evidence	Belum tenant partition/RLS organisasi

Area	Implementasi	Batas
Login abuse	Limit per IP dan username; blokir setelah kegagalan; shared budget password endpoints	Per proses; shared limiter diperlukan untuk scale-out
SQL	Values parameterized; dynamic identifier hanya map/whitelist domain	DDL dan custom schema perlu review setiap perubahan
Data integrity	PK/FK/UNIQUE/CHECK, transaksi, advisory lock, optimistic version	Beberapa relasi JSONB tetap logical references
HTTP	nosniff, DENY frame, no-referrer, permissions policy; HSTS production + Secure	HTTPS bergantung deployment; bukan TLS terminator bawaan
Origin/CSRF	Mutasi dengan Origin beda host ditolak; SameSite cookie	Tidak ada token CSRF khusus; missing-Origin diterima saat ini
File access	Auth/owner, path normalization, upload constraints, CSP sandbox file responses	Generic office/PDF belum malware scan
Upload abuse	4 active/process, 2/account, stream aggregate cap, temporary cleanup	Kapasitas disk/timeout deployment tetap perlu diuji
Content rendering	Vue interpolation, escapeHtml, DOMPurify pada rendering rich content terkait	Review seluruh innerHTML bukan pembuktian formal semua sink
Secrets	SMTP AES-256-GCM dengan key di data; cloud credentials runtime	Key/env perlu ACL dan salinan recovery terpisah
Audit	Request events, requestId, credential redaction, durable fallback queue	At-least-once; crash window dan duplikasi masih mungkin
Recovery	Dump semua tabel, ZIP metadata+file, restore invalidasi sesi	Restore file dapat parsial jika storage gagal; perlu retry terukur

Acuan praktik industri

Review menggunakan OWASP ASVS sebagai acuan ruang lingkup kontrol aplikasi, OWASP Authorization Cheat Sheet untuk least privilege dan pemeriksaan izin per request, serta node-postgres Transactions untuk transaksi satu client. Pemetaan ini adalah acuan review, bukan penilaian lengkap atau klaim memenuhi seluruh requirement ASVS.

Praktik coding dan review

Boundary HTTP harus memvalidasi input, parameter ID, ukuran dan tipe; domain service menghitung ulang nilai turunan serta memeriksa referensi. SQL values selalu parameterized. Setiap transaksi memakai satu client dan finally release. Mutasi multientitas harus atomik atau jelas melaporkan partial result. Server permission wajib, UI permission hanya membantu UX. Jangan interpolate konten pengguna ke HTML/CSS/URL tanpa encoding sesuai konteks.

Perubahan DB menggunakan additive migration dan backfill tervalidasi; perubahan destructive membutuhkan rencana recovery. File source frontend diedit, hasil build digenerasi. Lockfile di-review, minimum versi aman dipertahankan, audit diulang saat rilis. Jangan commit secret, cookie, dump bisnis, atau log sensitif.

Pekerjaan keamanan yang belum terverifikasi / rekomendasi

- Pentest terhadap deployment HTTPS/proxy aktual, session/cookie, IDOR, CSRF, injection, XSS, dan file preview.

- Uji S3/GCS/NAS/SMTP nyata dengan least-privilege runtime credentials, timeout dan failure behavior.
- Content Security Policy workspace yang kompatibel dengan runtime lama dan rich editor; CSP ketat belum dipaksakan untuk seluruh workspace.
- Pemeriksaan magic bytes semua dokumen, antivirus/quarantine, quota disk, dan uji upload paralel/beberapa akun.
- Shared session/limiter dan revocation lintas instance sebelum menjalankan multi-worker/replica.
- Normalisasi relasi logical JSONB bila perlu; formal tenant isolation bila aplikasi dipakai banyak organisasi.
- Infrastruktur DB role provisioning vs runtime least privilege. Role runtime startup sekarang membutuhkan hak DDL; Compose belum memisahkannya.
- Validasi backup/restore rehearsal, enkripsi arsip dan retensi off-host, serta monitoring antrean audit.

Daftar ini merupakan pekerjaan yang nyata belum dibuktikan dalam audit, sehingga laporan tidak menyatakan aplikasi "tanpa celah". Lihat dokumen keamanan historis di parent docs untuk perubahan sebelumnya; status terkini di bab ini dan bukti test yang dihasilkan.

Operasional, deployment, dan pengujian

Instalasi native

Siapkan Node sesuai engines package.json (^20.19 atau >=22.12), PostgreSQL kompatibel, client pg_dump/pg_restore, konfigurasi DB, folder persisten dan akun administrator. Perintah contoh dijalankan dari root proyek; environment contoh tidak berisi kredensial siap pakai.

```
npm.cmd ci
npm.cmd run build
npm.cmd run db:setup
npm.cmd run admin:create
npm.cmd start
```

Provisioning/startup menulis DDL/seed. Pastikan DB_HOST/PORT/NAME/USER provisioning dan pool mengacu instalasi yang sama. Detail akun administrator lihat scripts/create-admin.js dan dokumentasi instalasi; jangan menyisipkan password melalui source atau log.

Instalasi Docker

```
Copy-Item docker.env.example .env.docker
# Isi BLACKOWL_DB_PASSWORD dan sesuaikan bind/HTTPS pada .env.docker.
docker compose --env-file .env.docker up -d --build
docker compose --env-file .env.docker ps
docker compose --env-file .env.docker logs --tail 100 app
```

Default akses http://localhost:5000. Untuk jaringan pengguna set bind sesuai target; untuk produksi siapkan HTTPS/proxy dan Secure cookie. Jangan publikasikan DB port. Perintah tersebut adalah panduan, bukan deployment yang dijalankan saat pembuatan dokumen.

Rilis dan perubahan database

1. Simpan backup DB, file, konfigurasi dan kunci yang sudah diuji recovery-nya.

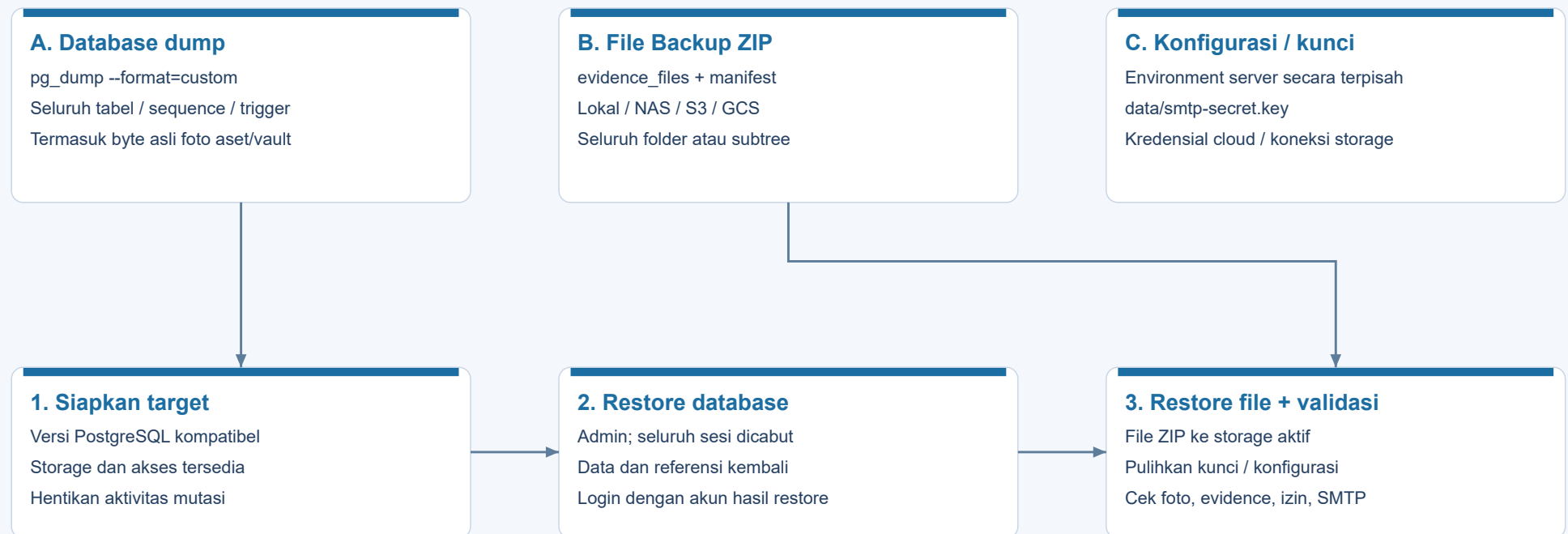
2. Review source diff, migrasi dan dependency lock; jalankan quality gate.
3. Build client/CSS; deploy runtime dan migrasi pada maintenance window.
4. Restart backend; session in-memory berakhir, pengguna login kembali.
5. Verifikasi login/permission, API read, contoh record, foto/evidence, versi diagram dan scheduler.
6. Monitor error startup, constraint, SMTP, audit recovery dan kapasitas storage.

FK vendor baru mempertahankan API managedVendorId, tetapi kini penghapusan vendor yang masih dipakai memberikan 409. Lepaskan vendor pengelola dari aset terlebih dahulu. Tidak menghapus data bisnis secara otomatis. Source map production tidak lagi dihasilkan. Session/limiter masih single-process.

Backup dan restore

Cakupan backup dan urutan pemulihan

Database, file, dan konfigurasi adalah artefak yang berbeda dan perlu dipulihkan bersama.



ZIP file tidak memulihkan record bisnis. Dump database tidak mencakup seluruh file eksternal atau kunci SMTP.

Backup/recovery

DB Backup memakai PostgreSQL custom dump dan mencakup struktur/data satu database aplikasi, seluruh modul dan byte foto dalam DB. Tidak mencakup seluruh role cluster atau semua file luar DB. File Backup ZIP berisi file terdaftar dan metadata manifest, dapat memilih folder/subtree, membaca lokasi asal termasuk cloud.

Batas ZIP upload/hasil arsip500 MiB; hasil ekstraksi2 GiB; masing-masing file500 MiB; max49.999 file dan manifest10 MiB. File restore mempertahankan path; file matching diganti, file lain tetap. Storage failure dapat menyisakan partial restore dan jumlah hasil harus diperiksa. Arsip sumber tidak boleh dipercaya sebelum validasi path/manifest/size.

Urutan recovery: hentikan mutasi, siapkan DB/storage kompatibel, restore database, pulihkan kunci/env/akses storage, restore file ZIP, login akun hasil restore, lalu cek referensi/foto/izin/email. Restore DB mencabut sesi pada awal/akhir termasuk gagal. Maintenance diperlukan karena request yang sudah lolos autentikasi tidak otomatis dibatalkan.

Pengujian dan quality gate

```
npm.cmd audit
npm.cmd test
npm.cmd run test:security
npm.cmd run test:i18n
npm.cmd run test:notes
npm.cmd run build
npm.cmd run test:asset-rack-browser
node scripts/test-asset-transfer.js
node scripts/test-uploaded-images-backup.js
```

Suite utama dapat melewati tes integrasi DB sesuai flag konfigurasi; skipped test tidak dianggap lulus integrasi. Script transfer memakai schema terisolasi; script foto/backup melakukan rollback fixture. Jangan menjalankan test mutasi terhadap database produksi tanpa membaca isolation/cleanup script. Test browser mock tidak membuktikan koneksi SMTP/cloud nyata atau pentest.

Bukti hasil pemeriksaan terbaru dirangkum dalam VALIDATION.md. Tidak menjalankan restore database produksi saat pemeriksaan dokumentasi. Build menghasilkan bundle cukup besar; peringatan bundle bukan kegagalan keamanan tetapi kandidat pemecahan modul untuk kinerja.

Troubleshooting

Gejala	Pemeriksaan
API401 setelah restart/password/restore	Login ulang; cookie/HTTPS configuration
API403	Page read + action, role admin-only, ownership, Origin/Host

Gejala	Pemeriksaan
API409 perangkat	Aset sudah dipasang, stale previousRackId, overlap atau kapasitas
API409 diagram/note	Muat version terbaru; jangan overwrite otomatis
API409 hapus vendor	Lepaskan managing vendor asset / relasi lebih dahulu
API413/429 upload	Ukuran per file/total, jumlah file, concurrency; retry setelah request selesai
DB connection/startup	Env, host/port, role DDL, DB health, migration referensi
Foto/evidence hilang	evidence_path, owner, lokasi asal storage, original DB bytes; status migration
SMTP gagal	Akun terpilih, host/port/TLS, from, relay permission dan key sesuai ciphertext
Backup dump gagal	pg_dump compatible major/server dan executable path
ZIP restore parsial	Storage connection/permission, count restored, retry setelah penyebab diperbaiki
UI versi lama	Build client; Ctrl+F5; pastikan server menyajikan generated index terbaru
audit-recovery berulang	DB outage, ACL data/audit-pending, queue/disk capacity

Hasil validasi 9 Oktober 2026

Pemeriksaan dilakukan terhadap source workspace lokal setelah perubahan. Tidak melakukan restore database produksi atau pengujian SMTP/cloud nyata.

Pemeriksaan	Hasil
npm audit setelah update	0 advisory; sebelum update 4 paket terdampak (3 high, 1 critical)
npm test	197 tes: 192 lulus, 5 skipped, 0 gagal
test:i18n	8 lulus, termasuk browser pergantian bahasa; percobaan paralel timeout, pengulangan terpisah lulus
test:notes	37 lulus
Build CSS + Vue	Berhasil; peringatan ukuran bundle/runtime stylesheet masih ada
Browser Asset Management	Lulus: foto/rack, tab, SMTP UI, drag/drop, diagram, zoom, modal, mobile; data mock
Vendor FK PostgreSQL	Lulus pada temporary tables: orphan insert/update dan referenced delete ditolak; vendor null/unlink diperbolehkan
Asset export/import PostgreSQL	Lulus pada schema terisolasi: ID remap, CIA/foto/layout, repeat import, rollback collision, Uploaded Files
Startup backend setelah update	Berhasil pada port8000; generated vendor column ALWAYS + satu FK terpasang
Source map frontend	Build tidak menghasilkan file .map

Bukti dependency tersedia pada validation/npm-audit-before.json dan validation/npm-audit-after.json. Log regresi utama di output/security-regression-2026-10-09.log pada repository. Pengujian tidak merupakan sertifikasi atau jaminan bebas kerentanan. Rekomendasi/pengujian deployment tersisa tercantum pada bab keamanan.

Transaksi reset risiko dan penyimpanan vendor/linked risks diuji untuk commit, rollback, dan pelepasan client.